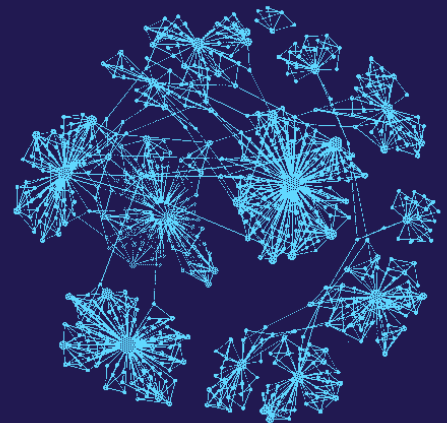

BSI Grundschutz++

Methodik

S. Dierkes



Inhaltsverzeichnis

Einleitung BSI Grundschutz++	7
Disclaimer	7
Lizenz	7
BSI Methodik Grundschutz++	8
Praktik: GC Governance und Compliance	9
Praktik: PERF Monitoring-Evaluation	10
Praktik: STM Strukturmodellierung	11
Praktik: UMS Umsetzung	12
Praktik: VRB Verbesserung	13
Control: GC.1.1 - Errichtung und Aufrechterhaltung eines ISMS	14
Control: GC.2.1 - Festlegung des externen Kontextes der Institution	15
Control: GC.2.2 - Festlegung des internen Kontextes der Institution	16
Control: GC.3.1 - Analyse der externen interessierten Parteien	17
Control: GC.3.2 - Analyse der internen interessierten Parteien	18
Control: GC.4.1 - Festlegung des Geltungsbereichs	19
Control: GC.5.1 - Vorgehen bei der Informationssicherheitseinstufung	20
Control: GC.5.1.1 - Festlegung der Geschäftsprozesse	21
Control: GC.5.1.2 - Festlegung des Schutzbedarfs	22
Control: GC.5.1.3 - Geschäftsprozesse mit hohem Schutzbedarf	23
Control: GC.6.1 - Festlegung von Zielen für die Informationssicherheit	24
Control: GC.6.1.1 - Festlegung einer Sicherheitsstrategie	25
Control: GC.6.1.2 - Verpflichtung der Institutionsleitung	26
Control: GC.6.1.3 - Erstellung einer Sicherheitsleitlinie	27

Control: GC.6.1.4 - Freigabe der Sicherheitsleitlinie	28
Control: GC.7.1 - Verfahren und Regelungen	29
Control: GC.7.1.1 - Gesetzliche Verpflichtungen	30
Control: GC.7.1.2 - Anhörung zuständiger Stellen	31
Control: GC.7.1.3 - Vertragliche Verpflichtungen	32
Control: GC.7.1.4 - Prävention von Verstößen	33
Control: GC.8.1 - Verfahren zur Ressourcenplanung	34
Control: GC.8.1.1 - Festlegung von Rollen und Zuständigkeiten	35
Control: GC.8.1.1.1 - Informationssicherheitsbeauftragter	36
Control: GC.8.1.1.1.1 - Vorspracherecht des Informationssicherheitsbeauftragten	38
Control: GC.8.1.2 - Stellvertreterregelungen	39
Control: GC.8.1.3 - Vermeidung von Interessenkonflikten	40
Control: GC.8.1.4 - Festlegung einer Sicherheitsorganisation	41
Control: GC.8.1.5 - Sicherstellung der Qualifikation	42
Control: GC.8.1.6 - Ressourcen für den Informationssicherheitsbeauftragten	43
Control: GC.9.1 - Festlegung eines Verfahrens zum Kommunikationsmanagement	44
Control: GC.9.1.1 - Externer Austausch zur Informationssicherheit	45
Control: GC.9.1.2 - Kommunikation im Projektmanagement	46
Control: GC.9.1.3 - Dokumentenlenkung	47
Control: GC.10.1 - Festlegung von Vorgehensweisen	48
Control: GC.10.2 - Freigabe von Vorgehensweisen	49
Control: GC.11.1 - Methodik für das Risikomanagement	50

Control: PERF.1.1 - Verfahren und Regelungen	51
Control: PERF.1.1.1 - Auswertung der Gefährdungslage	52
Control: PERF.1.1.2 - Auswertung des Umsetzungsplans	53
Control: PERF.1.1.3 - Auswertung von Auditergebnissen	54
Control: PERF.1.1.4 - Auswertung von Sicherheitsvorfällen	55
Control: PERF.2.1 - Überwachung der Einhaltung von Verpflichtungen	56
Control: PERF.3.1 - Aufbau und Pflege eines Auditprogramms	57
Control: PERF.3.1.1 - Erstellen eines Auditsplans	58
Control: PERF.3.1.2 - Planen von internen Audits	60
Control: PERF.3.1.3 - Auswahl des Auditteams	61
Control: PERF.3.1.4 - Umfang von Audits	62
Control: PERF.4.1 - Dokumentation von Auditergebnissen	63
Control: PERF.4.1.1 - Einheitliches Bewertungsschema	64
Control: PERF.4.1.2 - Kommunikation an Stakeholder	65
Control: PERF.5.1 - Eignungsprüfung	66
Control: PERF.5.1.1 - Ergebnisse von Folgemaßnahmen	67
Control: PERF.5.1.2 - Geänderte Rahmenbedingungen	68
Control: PERF.5.1.3 - Erfolge und Probleme	69
Control: PERF.5.1.4 - Interne Überprüfungen und Audits	70
Control: PERF.5.1.5 - Eignungsprüfung bisheriger Sicherheitsmaßnahmen	71
Control: PERF.5.1.6 - Rückmeldung von Stakeholdern	72
Control: PERF.5.1.7 - Status des Realisierungsplans	73
Control: PERF.5.1.8 - Verbesserungen	74

Control: PERF.5.1.9 - Maßnahmenvorschläge	75
Control: PERF.5.2 - Bericht an die Institutionsleitung	76
Control: PERF.6.1 - Sicherheitsvorfälle	77
Control: PERF.6.1.1 - Sicherheitsvorfälle	78
Control: PERF.6.1.2 - Schwachstellen	79
Control: PERF.6.1.3 - Bedrohungen	80
Control: PERF.7.1 - Aktualität der Anforderungen	81
Control: STM.1.1 - Definition und Abgrenzung des Informationsverbunds	82
Control: STM.1.2 - Dokumentation der externen Schnittstellen	83
Control: STM.2.1 - Erstellung eines Anforderungspakets	84
Control: STM.3.1 - ISMS-Anforderungen des Informationsverbundes	85
Control: STM.4.1 - Erfassung relevanter Assets	86
Control: STM.4.2 - Dokumentation relevanter Assets	87
Control: STM.4.3 - Mapping des Assets auf die Zielobjektkategorien	88
Control: STM.5.1 - Modellierung der Anforderungen mit Zielobjekt	89
Control: STM.5.2 - Vererbung von Zielobjektkategorien	90
Control: STM.5.3 - Konsolidierung und Redundanzprüfung	91
Control: STM.5.4 - Modellierung der Anforderungen ohne Zielobjektkategorie	92
Control: STM.6.1 - Auf Grund anforderungsloser Assets	93
Control: STM.6.2 - Auf Grund externer Verpflichtungen	94
Control: STM.7.1 - Überprüfung des gesetzten Sicherheitsniveaus	95
Control: STM.8.1 - Risikobetrachtung bei fehlenden Anforderungen	96

Control: STM.9.1 - Verteilung der führenden Zuständigkeiten	97
Control: STM.9.2 - Weitere Parameter	98
Control: UMS.1.1 - Ermittlung des Umsetzungsstatus	99
Control: UMS.2.1 - Bewertung des Restrisikos	100
Control: UMS.3.1 - Umsetzungsplanung	101
Control: UMS.3.2 - Priorisierung von Maßnahmen	102
Control: UMS.4.1 - Benennung von Umsetzungszuständigen	103
Control: UMS.4.2 - Festlegung von Umsetzungsfristen	104
Control: UMS.5.1 - Autorisierung von Ausnahmen	105
Control: UMS.5.2 - Dokumentation von Ausnahmen	106
Control: UMS.6.1 - Nachverfolgung des Umsetzungsfortschritts	107
Control: UMS.6.2 - Fortschreibung des Umsetzungsplans	108
Control: UMS.7.1 - Wahrung von Compliance in der Umsetzung	109
Control: VRB.1.1 - Verfahren zur kontinuierlichen Verbesserung	110
Control: VRB.1.2 - Änderungen im ISMS	111
Control: VRB.2.1 - Umgang mit Nicht-Konformitäten	112
Control: VRB.2.2 - Anpassung des ISMS	113
Control: VRB.3.1 - Identifikation von Verbesserungspotenzialen	114
Control: VRB.4.1 - Korrekturmaßnahmen	115
Control: VRB.4.2 - Verbesserungsmaßnahmen	116
Control: VRB.5.1 - Priorisierung von Maßnahmen	117
Control: VRB.6.1 - Wirksamkeitsprüfung	118
Control: VRB.7.1 - Bewertung der erreichten Verbesserung	119

Control: VRB.8.1 - Behandlung von Compliance-Verstößen

120

Einleitung BSI Grundschutz++

Dieses Dokument wurde automatisch generiert aus den OSCAL Dateien des BSI für den neuen Grundschutz++ und bildet den zum Zeitpunkt der Generierung verfügbaren Datenbestand ab.

Disclaimer

Dieses Dokument dient ausschließlich der Information, Dokumentation und internen Unterstützung.

Es wird keine Gewähr für die Richtigkeit, Vollständigkeit, Aktualität oder Eignung für einen bestimmten Zweck übernommen. Jegliche Nutzung erfolgt auf eigene Verantwortung. Vor operativen, fachlichen, rechtlichen oder regulatorischen Entscheidungen sind die Inhalte eigenständig zu prüfen und bei Bedarf fachlich zu validieren. Automatisch erzeugte Verknüpfungen, Klassifizierungen, Zuordnungen oder Auswertungen können vereinfachend sein und bedürfen gegebenenfalls einer manuellen Nachprüfung.

Lizenz

Dieses Dokument basiert auf Inhalten des **Bundesamts für Sicherheit in der Informationstechnik (BSI)** aus dem Projekt **Stand der Technik Bibliothek (Grundschutz++)**.

Originalquelle:

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek>

Verwendete Bestandteile:

- Anwendungskatalog (OSCAL)
- Namespace-Definitionen
- Quellkataloge

Die Originalinhalte stehen unter der Lizenz **Creative Commons Attribution-ShareAlike 4.0 International (CC BY-SA 4.0)**:

<https://creativecommons.org/licenses/by-sa/4.0/>

Dieses Dokument stellt eine bearbeitete bzw. transformierte Fassung dar und wird gemäß den Bedingungen der Lizenz ebenfalls unter **CC BY-SA 4.0** bereitgestellt.

BSI Methodik Grundschutz++

Norm

Beschreibung Quellkataloge

Version 0.9

zuletzt geändert 2026-04-20T11:58:14.333366Z

Keywords

URL

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Quellkataloge/Methodik-Grundschutz++/BSI-Methodik-Grundschutz++-catalog.json>

Rollen

ID Titel / Beschreibung

publisher Publisher

Referenzen

Relation Label / Link

Praktik: GC Governance und Compliance

Kürzel	GC
auch bekannt als	Corporate/Mission Governance und Compliance
Schwerpunkt	Methodik

Definition

Die Praktik Governance und Compliance stellt sicher, dass Informationssicherheitsstrategien mit den übergeordneten Zielen der Institution und regulatorischen Anforderungen im Einklang stehen. Sie vereint die strategische Steuerung der Informationssicherheit mit der systematischen Identifikation und Integration externer sowie interner Anforderungen.

Diese Praktik definiert den strategischen Rahmen für die Informationssicherheit und beantwortet die Fragen nach dem "Was" und "Warum" von Anforderungen und Sicherheitsmaßnahmen. Sie gewährleistet die Einbindung der obersten Führungsebene in wichtige Entscheidungen zur Informationssicherheit und stellt sicher, dass alle relevanten gesetzlichen, regulatorischen und vertraglichen Vorgaben identifiziert und berücksichtigt werden.

Während Governance und Compliance die strategische Ausrichtung und die Anforderungen definiert, übernehmen die operativen Praktiken wie Strukturmodellierung und Umsetzung die konkrete Ausgestaltung.

Untergeordnete Gruppen:

- GC.1 Grundlagen
- GC.2 Festlegung des Kontextes der Institution
- GC.3 Analyse der interessierten Parteien
- GC.4 Festlegung des Geltungsbereichs
- GC.5 Prozess der Informationssicherheitseinstufung
- GC.6 Entwicklung einer Sicherheitsleitlinie
- GC.7 Implementierung des Compliance-Managements
- GC.8 Sicherheitsorganisation und Rollen
- GC.9 Dokumentation und Kommunikation
- GC.10 Festlegung und Freigabe der Vorgehensweise
- GC.11 Initiierung des Risikomanagements

Praktik: PERF Monitoring-Evaluation

Kürzel	PERF
auch bekannt als	Kontinuierliche Überprüfung
Schwerpunkt	Methodik

Definition

Die Praktik Monitoring-Evaluation stellt durch kontinuierliche Überwachung und systematische Bewertung sicher, dass die implementierten Sicherheitsmaßnahmen wirksam sind und die Sicherheitsziele der Organisation erreicht werden. Sie liefert Erkenntnisse über den aktuellen Sicherheitszustand und identifiziert Verbesserungspotentiale.

Im Rahmen dieser Praktik werden regelmäßige Sicherheitsaudits, kontinuierliches Monitoring von Sicherheitsereignissen sowie periodische Überprüfungen und Bewertungen des ISMS durchgeführt. Sie entspricht der "Check-Phase" im PDCA-Zyklus und dient dazu, Abweichungen von den definierten Zielen zu erkennen.

Die Ergebnisse der Monitoring-Evaluation fließen direkt in die Praktik Verbesserung ein, wo konkrete Maßnahmen zur Behebung identifizierter Schwachstellen und zur kontinuierlichen Weiterentwicklung des ISMS abgeleitet werden.

Untergeordnete Gruppen:

- PERF.1 Leistungsbewertung des ISMS
- PERF.2 Überwachung der Compliance
- PERF.3 Auditprogramm und -durchführung
- PERF.4 Bewertungsschema und Auditberichte
- PERF.5 Managementbewertungen
- PERF.6 Monitoringmethoden und -tools
- PERF.7 Validierung der Anforderungen

Praktik: STM Strukturmodellierung

Kürzel	STM
auch bekannt als	Modellierung
Schwerpunkt	Methodik

Definition

Die Praktik Strukturmodellierung bildet die Grundlage für eine systematische Analyse der Informationssicherheit einer Institution.

Ziel der Strukturmodellierung ist aus dem Stand-der-Technik-Kompendium ein individuelles Anforderungspaket für die Institution zu generieren. Auf Basis der Geschäftsprozesse und Informationen wird der individuelle Schutzbedarf festgelegt. Mit der Zuordnung einzelner Praktiken und Zielobjekte erfolgen eine Auswahl von Anforderungen auf der Grundlage des vorgegebenen Schutzniveaus. Blaupausen unterstützen die Filterung der Anforderungen. Eine Klassifizierung des Schutzbedarfs der Zielobjekte erfolgt auf Anforderungsebene. Die individuelle Anpassung der Anforderungen durch Auswahlmöglichkeiten erleichtern eine Skalierung. Eine Erweiterung des Anforderungspakets durch spezifische Anforderungen erhöht die Flexibilität. Für diese Anforderungen ist eine Risikobetrachtung erforderlich.

Die Strukturmodellierung liefert essentielle Eingangsdaten für die nachgelagerten Praktiken wie Umsetzung und Monitoring-Evaluation und ermöglicht eine zielgerichtete und risikoorientierte Planung von Anforderungen und Sicherheitsmaßnahmen.

Untergeordnete Gruppen:

- STM.1 Definition und Abgrenzung des Informationsverbunds
- STM.2 Erstellung eines Anforderungspakets
- STM.3 ISMS-Anforderungen des Informationsverbundes
- STM.4 Asset-Modellierung
- STM.5 Anforderungsmodellierung auf die Assets
- STM.6 Anforderungsergänzung
- STM.7 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8 Durchführung der Risikobetrachtung
- STM.9 Gestaltungsentscheidungen

Praktik: UMS Umsetzung

Kürzel	UMS
auch bekannt als	Realisierung von Sicherheitsmaßnahmen
Schwerpunkt	Methodik

Definition

Die Praktik Umsetzung sorgt für die systematische Planung, Implementierung und Dokumentation von Anforderungen bzw. der Sicherheitsmaßnahmen, die aus der Strukturmodellierung und Risikobewertung abgeleitet wurden. Sie stellt sicher, dass identifizierte Sicherheitsanforderungen effektiv in die organisatorischen und technischen Prozesse integriert werden.

Diese Praktik umfasst die detaillierte Planung von Maßnahmen, die Festlegung von Verantwortlichkeiten und Zeitplänen sowie die Bereitstellung notwendiger Ressourcen. Zudem beinhaltet sie die Nachverfolgung der Implementierung und die Dokumentation der umgesetzten Maßnahmen.

Während die Praktik Strukturmodellierung die notwendigen Anforderungen identifiziert und die Praktik Monitoring-Evaluation die Wirksamkeit der Maßnahmen überprüft, konzentriert sich die Umsetzung auf die effiziente und effektive Realisierung der erforderlichen Sicherheitsmaßnahmen.

Untergeordnete Gruppen:

- UMS.1 Ermittlung des Umsetzungsstatus
- UMS.2 Bewertung fehlender Umsetzungen
- UMS.3 Umsetzungsplanung und Priorisierung
- UMS.4 Zuständigkeiten und Umsetzungsfristen
- UMS.5 Freigabeverfahren und Ausnahmemanagement
- UMS.6 Fortschrittsverfolgung der Realisierung
- UMS.7 Wahrung von Compliance in der Umsetzung

Praktik: VRB Verbesserung

Kürzel	VRB
auch bekannt als	Kontinuierliche Verbesserung
Schwerpunkt	Methodik

Definition

Die Praktik Verbesserung gewährleistet die kontinuierliche Weiterentwicklung und Optimierung des Informationssicherheitsmanagementsystems. Sie nutzt die Erkenntnisse aus dem Monitoring und der Evaluation, um die Wirksamkeit der Sicherheitsmaßnahmen zu erhöhen.

Diese Praktik umfasst die Planung und Umsetzung von Korrektur- und Vorbeugungsmaßnahmen. Ziel ist es, einen Prozess der kontinuierlichen Verbesserung zu etablieren, der flexibel auf neue Bedrohungen und veränderte Rahmenbedingungen reagieren kann.

Die Verbesserung schließt den PDCA-Zyklus ab und leitet gleichzeitig einen neuen Zyklus ein, indem sie Impulse für Anpassungen in den Praktiken Governance und Compliance, Strukturmodellierung und Umsetzung gibt. Sie stellt sicher, dass das ISMS dynamisch bleibt und sich an veränderte Anforderungen und Bedrohungen anpasst.

Untergeordnete Gruppen:

- VRB.1 Kontinuierliche Verbesserung
- VRB.2 Umgang mit Nicht-Konformitäten
- VRB.3 Identifikation von Verbesserungspotenzialen
- VRB.4 Korrektur- und Verbesserungsvorschläge
- VRB.5 Korrektur- und Verbesserungsplan
- VRB.6 Wirksamkeitsprüfung
- VRB.7 Bewertung der erreichten Verbesserung
- VRB.8 Behandlung von Compliance-Verstößen

Control: GC.1.1 - Errichtung und Aufrechterhaltung eines ISMS

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.1 Grundlagen

UUID: 80351189-6ffc-495e-a995-6219b9704724

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS Verfahren und Regelungen zur Errichtung und Aufrechterhaltung eines ISMS nach {{ insert: param, gc.1.1-prm1 }} verankern.

Guidance

Diese Anforderung ist der Ausgangs- und Endpunkt für ein Informationssicherheitsmanagementsystem (ISMS). Ein ISMS besteht aus Verfahren (d.h. bestimmten Abläufen, die mit Zuständigkeiten und Ressourcen versehen sind) und Regelungen (also festgelegten Regeln, die von allen Mitarbeitenden und sonstigen Verpflichteten einzuhalten oder technisch umgesetzt sind). Die Anforderung ist erst dann als erfüllt anzusehen, wenn die komplette Vorgehensweise mindestens einmal vollständig durchlaufen wurde. Unter „etabliert“ bzw. „errichtet“ ist hier zu verstehen, dass die Anforderungen an das ISMS standardkonform umgesetzt wurden. Unter „aufrechterhalten“ ist hier zu verstehen, dass die Einhaltung der Anforderungen kontinuierlich überprüft wird und bei Bedarf Gegenmaßnahmen eingeleitet werden. Die bei der Festlegung der Verfahren und Regelungen im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den weiteren Anforderungen dieses Anwenderkataloges.

Control: GC.2.1 - Festlegung des externen Kontextes der Institution

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.2 Festlegung des Kontextes der Institution

UUID: 7adcac0b-cc2c-43d4-8528-28d78beed631

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten externen Rahmenbedingungen verankern.

Guidance

Analysieren und dokumentieren Sie systematisch alle externen Faktoren, die einen Einfluss auf die Informationssicherheitsziele und -strategie der Institution haben. Dazu zählen insbesondere Faktoren, die von außen auf die Institution einwirken wie z.B. gesellschaftliche und kulturelle Faktoren, die die Erwartungen an die Institution prägen; rechtliche und regulatorische Rahmenbedingungen auf nationaler und internationaler Ebene; technologische Entwicklungen und deren Auswirkungen auf die Informationssicherheit; wirtschaftliche Bedingungen im relevanten Marktumfeld und ökologische und physische Umweltbedingungen am Standort der Institution.

Links

related: GC.2.2 Festlegung des internen Kontextes der Institution

Control: GC.2.2 - Festlegung des internen Kontextes der Institution

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.2 Festlegung des Kontextes der Institution

UUID: facd5982-78f3-46d4-ae07-ae1ede72ab46

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten internen Rahmenbedingungen verankern.

Guidance

Analysieren und dokumentieren Sie systematisch alle internen Faktoren, die einen Einfluss auf die Informationssicherheitsziele und -strategie der Institution haben. Dazu zählen institutionseigene Faktoren wie z.B. vorhandene Institutionsstrategien, Werte und Institutionsziele; die Institutionsstruktur mit Hierarchien, Abteilungen und Zuständigkeitsbereichen; die in Ihrer Institution etablierte Prozesse und Arbeitsabläufe; vorhandene IT-Infrastruktur und Informationssysteme und die Institutionskultur und Einstellungen zur Sicherheit.

Links

related: GC.2.1 Festlegung des externen Kontextes der Institution

Control: GC.3.1 - Analyse der externen interessierten Parteien

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.3 Analyse der interessierten Parteien

UUID: 834c85a0-f793-4d6a-8eba-5f26f38979cd

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS ein Verfahren zum Ermitteln aller externen interessierten Parteien und ihrer Bedürfnisse und Erwartungen an das Informationsicherheitsmanagement der Institution verankern.

Guidance

Alle relevanten externen interessierten Parteien sind ermittelt. Die externen interessierten Parteien umfassen beispielsweise: Gesetzgeber, Aufsichtsbehörden, Kunden, Dienstleister, Gesellschaft/Öffentlichkeit. Die Relevanz und Priorität der identifizierten Anforderungen sind zu bewerten und auf Grundlage dessen ist festzulegen, welche dieser Anforderungen als verbindliche Verpflichtungen in das ISMS aufgenommen werden.

Links

related: GC.3.2 Analyse der internen interessierten Parteien

Control: GC.3.2 - Analyse der internen interessierten Parteien

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.3 Analyse der interessierten Parteien
UUID: 491ec81c-443b-4792-83f3-c9f4363c64ce
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS ein Verfahren zum Ermitteln aller internen interessierten Parteien und ihrer Bedürfnisse und Erwartungen an das Informationsicherheitsmanagement der Institution verankern.

Guidance

Alle relevanten externen interessierten Parteien sind ermittelt. Die internen interessierten Parteien umfassen beispielsweise: Geschäftsführung, Mitarbeiter, Führungskräfte, Betriebsrat/Personalrat.

Links

related: GC.3.1 Analyse der externen interessierten Parteien

Control: GC.4.1 - Festlegung des Geltungsbereichs

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.4 Festlegung des Geltungsbereichs

UUID: ebff4c7b-77b1-4d08-bc57-37d3ca16242c

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS den nachvollziehbar abgegrenzten Geltungsbereich nach Freigabe der Institutionsleitung festlegen.

Guidance

Definieren und dokumentieren Sie den Geltungsbereich Ihres ISMS. Dieser legt den formalen und organisatorischen Umfang (Scope) fest, in dem das ISMS angewendet wird. Legen Sie fest, welche Institutionsbereiche, Geschäftsprozesse und Tätigkeiten formell zum Geltungsbereich gehören und grenzen Sie infrastrukturell ab, welche Standorte und Systeme innerhalb des Geltungsbereichs liegen; welche externen Partner oder Dienstleister in das ISMS einzubeziehen sind und welche Bereiche bewusst nicht Bestandteil des Geltungsbereichs sind.

Links

required: GC.3.2 Analyse der internen interessierten Parteien

required: GC.3.1 Analyse der externen interessierten Parteien

required: GC.2.2 Festlegung des internen Kontextes der Institution

required: GC.2.1 Festlegung des externen Kontextes der Institution

Control: GC.5.1 - Vorgehen bei der Informationssicherheitseinstufung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.5 Prozess der Informationssicherheitseinstufung
UUID: bdbc4d9b-c0d7-4f5a-8e07-ba12b4049625
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf

Statement

Governance und Compliance MUSS ein Verfahren für die Festlegung von Geschäftsprozessen und die Einstufung des Schutzbedarfs dieser Geschäftsprozesse und den hierbei verarbeiteten Informationen verankern.

Guidance

Die Informationssicherheitseinstufung dient der systematischen Identifikation des Schutzbedarfs von Geschäftsprozessen und verarbeiteten Informationen. Hierbei wird zwischen dem Schutzbedarf „normal“ und „hoch“ unterschieden. Der prozessorientierte Ansatz stellt die Verbindung zwischen Geschäftsprozessen und Informationen in den Vordergrund.

Control: GC.5.1.1 - Festlegung der Geschäftsprozesse

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.5 Prozess der Informationssicherheitseinstufung
Übergeordnetes Control:
GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
UUID: b75cea5b-dc1e-4b96-b34a-5053242dabc1
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS die Geschäftsprozesse die für den Geltungsbereich relevant sind festlegen.

Guidance

Hierbei kann oft auf bestehende Prozesslandkarten und Managementsysteme zurückgegriffen werden. Besteht noch keine Prozessübersicht in der Institution, so können die technischen und organisatorischen Praktiken als Ausgangsvorschlag für relevante Hilfsprozesse herangezogen werden (siehe Prozessschritt 2 - Anforderungsanalyse)

Links

related: GC.4.1 Festlegung des Geltungsbereichs

Control: GC.5.1.2 - Festlegung des Schutzbedarfs

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.5 Prozess der Informationssicherheitseinstufung
Übergeordnetes Control:
GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
UUID: 7a951196-bf44-463f-91b6-8cf140c97e4c
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS eine Einstufung des Schutzbedarfs der relevanten Geschäftsprozesse und Informationsarten unter Berücksichtigung der Geschäftsziele und in Absprache mit der Institutionsleitung festlegen.

Guidance

Das Ergebnis der Schutzbedarfsfeststellung ist eine Übersicht des Schutzbedarfs der zu verarbeitenden Informationen, sowie der Relevanz der Geschäftsprozesse. Die Einstufung erfolgt dabei in den Stufen „normal“ oder „hoch“. Die Einstufung richtet sich nach der Bedeutung des Geschäftsprozess für die Geschäftsziele oder den gesetzlichen Auftrag der Institution. Priorität für die weitere Abarbeitung hat zunächst der wichtigste Geschäftsprozess, d.h. derjenige Geschäftsprozess, dessen Informationsschutz für den Fortbestand der Institution von essentieller Bedeutung ist. Die Entscheidung darüber, welcher Geschäftsprozess am wichtigsten ist, obliegt der Institutionsleitung. Droht bei einer Verletzung der Vertraulichkeit, Integrität oder Verfügbarkeit von Informationen in diesem Geschäftsprozess ein existenzbedrohender finanzieller oder existenzbedrohender Reputationsschaden, so ist der Schutzbedarf des Prozesses als hoch einzustufen. Das gleiche gilt, wenn innerhalb eines Geschäftsprozesses Informationen verarbeitet werden, die als besonders vertraulich eingestuft werden.

Links

required: GC.5.1.1 Festlegung der Geschäftsprozesse

Control: GC.5.1.3 - Geschäftsprozesse mit hohem Schutzbedarf

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.5 Prozess der Informationssicherheitseinstufung
Übergeordnetes Control:
GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
UUID: c86010f0-6e07-429a-a203-529ebdc6c99a
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS eine dedizierte Risikobetrachtung von Geschäftsprozessen oder Informationsarten mit hohem Schutzbedarf ausführen.

Guidance

In einem separaten Dokument zur Risikobetrachtung werden verbindliche Vorgaben an die Risikomethodik vorgeschrieben.

Links

required: GC.5.1.2 Festlegung des Schutzbedarfs

Control: GC.6.1 - Festlegung von Zielen für die Informationssicherheit

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.6 Entwicklung einer Sicherheitsleitlinie
UUID: 551fec73-dce4-4f34-b41d-555142b09cf7
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie

Statement

Governance und Compliance MUSS konkrete und messbare Ziele für die Informationssicherheit auf Basis der identifizierten Rahmenbedingungen festlegen.

Guidance

Die Ziele sollten Bezug zu den Geschäftszielen der Institution aufweisen und müssen messbar und konkret sein, z. B.: 98% der aktiven Endgeräte im Netzwerk der Institution verfügen über eine aktuelle Antivirensoftware, deren Signaturdatenbank nicht älter als 24 Stunden ist. Die Ziele sollten die Anforderungen der interessierten Parteien sowie den Kontext berücksichtigen.

Control: GC.6.1.1 - Festlegung einer Sicherheitsstrategie

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.6 Entwicklung einer Sicherheitsleitlinie
Übergeordnetes Control:
GC.6.1 Festlegung von Zielen für die Informationssicherheit
UUID: a13fb400-1756-4708-b212-502d284c4308
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance SOLLTE eine grundlegende Strategie zur Erreichung der Ziele für die Informationssicherheit gemeinsam mit der Institutionsleitung festlegen.

Guidance

Die Sicherheitsstrategie legt fest, wie die Organisation die Ziele erreichen möchte und fokussiert insbesondere den übergeordneten Ansatz und die Prinzipien.

Links

required: GC.6.1 Festlegung von Zielen für die Informationssicherheit

Control: GC.6.1.2 - Verpflichtung der Institutionsleitung

Tag: "Führungsverantwortung"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.6 Entwicklung einer Sicherheitsleitlinie
Übergeordnetes Control:
GC.6.1 Festlegung von Zielen für die Informationssicherheit
UUID: 8b3ae6fa-4bd0-4d81-babe-7792c63b9989
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS die Verpflichtung der Institutionsleitung formal zuweisen.

Guidance

Die Verpflichtung der Institutionsleitung beinhaltet die Übernahme der Gesamtverantwortung, die Bestätigung und Überwachung der Informationssicherheitsziele bezüglich der Organisationsziele und die Förderung des ISMS. Die Förderung des ISMS erfolgt durch Beteiligung (z. B. Führungsentscheidungen), Bestätigung der Informationssicherheitsorganisation, Unterstützung der Integration des ISMS, Bereitstellung von Ressourcen (z. B. finanzielle, personelle, technische, infrastrukturelle) und die Unterstützung der kontinuierlichen Verbesserung.

Control: GC.6.1.3 - Erstellung einer Sicherheitsleitlinie

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.6 Entwicklung einer Sicherheitsleitlinie
Übergeordnetes Control:
GC.6.1 Festlegung von Zielen für die Informationssicherheit
UUID: af7b68e3-ac36-4876-a1ea-80d38407f1c1
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS eine für die Institution passende Sicherheitsleitlinie festlegen.

Guidance

Die Sicherheitsleitlinie ist ein zentrales Dokument, welches an alle Mitarbeitenden kommuniziert werden muss. Sie dient als Orientierung für alle sicherheitsrelevanten Entscheidungen und Aktivitäten und fördern ein gemeinsames Verständnis der Bedeutung und Ausrichtung der Informationssicherheit. Die Leitlinie für Informationssicherheit enthält insbesondere die Gesamtverantwortung und Verpflichtung der Institutionsleitung, Informationssicherheitsziele, eine Informationssicherheitsstrategie, die Benennung der Rollen und Zuständigkeiten sowie die Verpflichtung zur kontinuierlichen Verbesserung.

Control: GC.6.1.4 - Freigabe der Sicherheitsleitlinie

Tag: "Führungsverantwortung"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.6 Entwicklung einer Sicherheitsleitlinie
Übergeordnetes Control:
GC.6.1 Festlegung von Zielen für die Informationssicherheit
UUID: 230dbdf5-8328-4629-8734-1b2f4288d5eb
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS die festgelegte Sicherheitsleitlinie durch die Institutionsleitung autorisieren.

Links

required: GC.6.1.3 Erstellung einer Sicherheitsleitlinie

Control: GC.7.1 - Verfahren und Regelungen

Tag: "Compliance Management"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.7 Implementierung des Compliance-Managements
UUID: de07bcb3-2a0b-44d4-bd3f-eca08ce44992
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen

Statement

Governance und Compliance MUSS ein Verfahren zur Sammlung, Integration und Priorisierung aller für das Informationssicherheitsmanagement relevanten Rahmenbedingungen verankern.

Guidance

Das Compliance Management stellt sicher, dass alle gesetzlichen, regulatorischen und vertraglichen Verpflichtungen im Bereich der Informationssicherheit eingehalten werden. Identifizieren, überwachen und bewerten Sie Verpflichtungen, um rechtliche Konsequenzen, finanzielle Verluste oder Reputationsschäden zu vermeiden. Aufgrund der hohen Komplexität des modernen Rechts ist für die Rechtspflege eine eigene Rechtsabteilung oder die Beauftragung von Mitgliedern der rechtsberatenden Berufe zweckmäßig. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Links

related: PERF.2.1 Überwachung der Einhaltung von Verpflichtungen

Control: GC.7.1.1 - Gesetzliche Verpflichtungen

Tags: "Compliance Management" "Inventories"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.7 Implementierung des Compliance-Managements
Übergeordnetes Control:
GC.7.1 Verfahren und Regelungen
UUID: 02747a0f-cd38-4815-9eec-351ae89dbdfe
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance SOLLTE die Analyse der gesetzlichen Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, ausführen.

Guidance

Gesetzliche Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, sind dokumentiert. Gesetzliche Verpflichtungen meint alle Pflichten, die sich unmittelbar aus dem Recht ergeben, inklusive des Verfassungsrechts, Europarechts und Verordnungen. Relevante gesetzliche Verpflichtungen können sich je nach Institution z. B. aus Grundrechten, Cyber Resilience Act, Data Act, Data Markets Act, NIS, DSGVO, BDSG, TKG, TDDDG oder GeschGehG ergeben. Beachten Sie dabei auch Verpflichtungen, die sich mittelbar auswirken wie die Arbeitsstättenverordnung oder allgemeine Regelungen zur Fürsorgepflicht.

Control: GC.7.1.2 - Anhörung zuständiger Stellen

Tag: "Compliance Management"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.7 Implementierung des Compliance-Managements
Übergeordnetes Control:
GC.7.1 Verfahren und Regelungen
UUID: 3d677306-5748-405a-b5f3-cdc2939e7d14
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance SOLLTE für die Einhaltung gesetzlicher Verpflichtungen in der Informationsverarbeitung zuständige Stellen in der Institution anhören.

Guidance

Für die Einhaltung gesetzlicher Verpflichtungen in der Informationsverarbeitung zuständige Stellen in der Institution wurden bei der Dokumentation der Compliance-Verpflichtungen angehört. Hierunter können z. B. Rechtsabteilung, Datenschutzbeauftragte, Brandschutzbeauftragte oder Fachverantwortliche bei branchenspezifischen Vorschriften fallen.

Control: GC.7.1.3 - Vertragliche Verpflichtungen

Tag: "Compliance Management"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.7 Implementierung des Compliance-Managements
Übergeordnetes Control:
GC.7.1 Verfahren und Regelungen
UUID: fc2115c2-43fe-4b22-88c5-b28784174936
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance SOLLTE die Zusammenstellung vertraglicher Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, dokumentieren.

Guidance

Vertragliche Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen, sind dokumentiert. Vertragliche Verpflichtungen meint alle Pflichten, die sich aus rechtlich bindenden Vereinbarungen ergeben, unabhängig davon, ob diese als Vertrag bezeichnet werden oder nicht.

Control: GC.7.1.4 - Prävention von Verstößen

Tag: "Compliance Management"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.7 Implementierung des Compliance-Managements
Übergeordnetes Control:
GC.7.1 Verfahren und Regelungen
UUID: 6874056a-4f01-497d-8ef4-0411a55671e7
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance SOLLTE Verfahren zur Prävention gegen Verstöße verankern.

Guidance

Verfahren können z. B. zielgruppengerechte Schulungen der für die Umsetzung und Einhaltung zuständigen Personen, die Berücksichtigung der Compliance-Verpflichtungen bei Freigabe- und Testprozessen sowie die Förderung einer konstruktiven Fehlerkultur sein.

Control: GC.8.1 - Verfahren zur Ressourcenplanung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.8 Sicherheitsorganisation und Rollen

UUID: 4378f5ac-3387-408e-974a-b04e5079c372

Aufwand: 0

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten

Statement

Governance und Compliance MUSS ein Verfahren zur kontinuierlichen, wirtschaftlichen Planung von Ressourcen für das ISMS verankern.

Guidance

Die Ressourcenplanung berücksichtigt die personellen, finanziellen und materiellen bzw. technischen Ressourcen.

Links

related: GC.6.1.2 Verpflichtung der Institutionsleitung

Control: GC.8.1.1 - Festlegung von Rollen und Zuständigkeiten

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.8 Sicherheitsorganisation und Rollen
Übergeordnetes Control:
GC.8.1 Verfahren zur Ressourcenplanung
UUID: 5cc59bb1-af0d-457f-a548-03373447fec7
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GC.8.1.1.1 Informationssicherheitsbeauftragter

Statement

Governance und Compliance MUSS die Rollen und Zuständigkeiten im Rahmen des ISMS inklusive ihrer Kompetenzen bzw. Befugnisse zuweisen.

Guidance

Im Rahmen des ISMS sind die Rollen hinsichtlich der Aufgaben, der dafür notwendigen Qualifikation und der notwendigen Befugnisse festgelegt. Eine zentrale Rolle wäre beispielsweise der "Informationssicherheitsbeauftragte" (ISB).

Control: GC.8.1.1.1 - Informationssicherheitsbeauftragter

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.8 Sicherheitsorganisation und Rollen
Übergeordnetes Control:
GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
UUID: 96ebe8f3-2419-45d0-b981-dc973d21c17c
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten

Statement

Governance und Compliance MUSS die Rolle des Informationssicherheitsbeauftragten {{ insert: param, gc.8.1.1.1-prm1 }} , welche unmittelbar der Institutionsleitung unterstellt ist, zuweisen.

Guidance

Informationssicherheit liegt in der Verantwortung der Institutionsleitung. Die operative Aufgabe „Informationssicherheit“ wird an einen Informationssicherheitsbeauftragten (ISB) delegiert, der diese Aufgabe innerhalb der Institution koordiniert und vorantreibt. Daher ist diese Rolle in jeder Institution (unabhängig von Art und Größe) zu besetzen. Je nach Art und Ausrichtung der Institution wird der ISB anders genannt. Häufige Titel sind neben dem Informationssicherheitsbeauftragten, Chief Information Security Officer (CISO) oder Informationssicherheitsmanager (ISM). Die Hauptaufgabe des ISB besteht darin, die Institutionsleitung bei deren Aufgabenwahrnehmung bezüglich der Informationssicherheit zu beraten und diese bei der Umsetzung zu unterstützen. Zu den ISB-Aufgaben gehört es u.a., den Sicherheitsprozess operativ zu steuern und zu koordinieren, die Institutionsleitung bei der Erstellung der Sicherheitsleitlinie zu unterstützen, die Erstellung des Sicherheitskonzepts und zugehöriger Teilkonzepte und Richtlinien zu koordinieren, den Umsetzungsplan für Sicherheitsmaßnahmen anzufertigen, sowie ihre Umsetzung zu initiieren und zu überprüfen, der Institutionsleitung und anderen Sicherheitsverantwortlichen über den Status der Informationssicherheit zu berichten, sicherheitsrelevante Projekte zu ko-

ordinieren, sicherheitsrelevante Vorfälle zu untersuchen, sowie Sensibilisierungen und Schulungen zur Informationssicherheit zu initiieren und zu koordinieren.

Control: GC.8.1.1.1.1 - Vorspracherecht des Informationssicherheitsbeauftragten

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.8 Sicherheitsorganisation und Rollen
Übergeordnetes Control:
GC.8.1.1.1 Informationssicherheitsbeauftragter
UUID: 2daf1f95-862a-4b5e-9d63-90723384a0df
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS das direkte Vorspracherecht des ISB bei der Institutionsleitung verankern.

Guidance

Das Vorspracherecht trägt dazu bei, dass die Institutionsleitung ein vollständiges und unverfälschtes Bild über den Stand der Informationssicherheit erhält. Ohne dieses direkte Vorspracherecht kann es passieren, dass andere Organisationseinheiten sicherheitsrelevante Informationen in der Weitergabe beeinflussen.

Control: GC.8.1.2 - Stellvertreterregelungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.8 Sicherheitsorganisation und Rollen

Übergeordnetes Control:

GC.8.1 Verfahren zur Ressourcenplanung

UUID: 0d09d72c-92af-4749-9ce1-a523f0546e46

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS Stellvertreterregelungen für alle relevanten Rollen und Zuständigkeiten im ISMS zuweisen.

Guidance

Eine kontinuierliche Handlungsunfähigkeit der Sicherheitsorganisation kann nur mit Stellvertreterregelungen für alle relevanten Rollen gewährleistet werden.

Control: GC.8.1.3 - Vermeidung von Interessenkonflikten

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.8 Sicherheitsorganisation und Rollen

Übergeordnetes Control:

GC.8.1 Verfahren zur Ressourcenplanung

UUID: e57f0e21-92f1-4ddb-8248-e74613905d7d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS Maßnahmen zur Vermeidung von Interessenkonflikten bei der Festlegung von Rollen und Zuständigkeiten des ISMS festlegen.

Guidance

Für die Vermeidung von Interessenkonflikten wird insbesondere die Zuordnung konkurrierender Rollen (bspw. ausführender und prüfender oder freigebender Rollen) vermieden. Dies erfolgt beispielsweise durch eine entsprechende Etablierung von Rollen in der Aufbauorganisation (z. B. Informationssicherheitsbeauftragter als Stabstelle). Es können aber auch weitere Maßnahmen (z. B. Vier-Augen-Prinzip) genutzt werden.

Links

required: GC.8.1.1 Festlegung von Rollen und Zuständigkeiten

Control: GC.8.1.4 - Festlegung einer Sicherheitsorganisation

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.8 Sicherheitsorganisation und Rollen
Übergeordnetes Control:
GC.8.1 Verfahren zur Ressourcenplanung
UUID: 56907e29-773a-4339-8166-785b68f9c065
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS die Sicherheitsorganisation für das ISMS mit den festgelegten Rollen, Zuständigkeiten sowie Gremien festlegen.

Guidance

Ziel der Sicherheitsorganisation ist es, die relevanten Bereiche eines ISMS sowie die relevanten Schnittstellen zu anderen Bereichen (z. B. Datenschutz, physische Sicherheit, Geheimschutz oder Arbeitsschutz) vollständig und wirksam in der Institution zu verankern. Die Sicherheitsorganisation sollte in einem Organigramm oder einer ähnlichen Darstellung dokumentiert und abgebildet werden.

Links

required: GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
required: GC.8.1.5 Sicherstellung der Qualifikation

Control: GC.8.1.5 - Sicherstellung der Qualifikation

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.8 Sicherheitsorganisation und Rollen

Übergeordnetes Control:

GC.8.1 Verfahren zur Ressourcenplanung

UUID: 09da6b52-1efc-4c44-98b3-4d9b094fd107

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS für jeden Rollen- und Verantwortungsträger die erforderlichen Anforderungen und Fähigkeiten festlegen.

Guidance

Für jeden Rollen- und Verantwortungsträger sind die Anforderungen und Fähigkeiten festgelegt.

Control: GC.8.1.6 - Ressourcen für den Informationssicherheitsbeauftragten

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.8 Sicherheitsorganisation und Rollen
Übergeordnetes Control:
GC.8.1 Verfahren zur Ressourcenplanung
UUID: b04f2734-0b3f-400f-92cb-08a49fb2960f
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS dem Informationssicherheitsbeauftragten {{ insert: param, gc.8.1.6-prm1 }} Ressourcen zuweisen.

Guidance

Zu den Aufgaben des ISB gehören beispielsweise die Beratung der Institutionsleitung zur Informationssicherheit, die Koordinierung der Erstellung von Richtlinien und Sicherheitskonzepten und die Untersuchung von Sicherheitsvorfällen. Ohne ausreichende Ressourcen, können diese Aufgaben nicht wirksam und nachhaltig wahrgenommen werden, was zu Sicherheitsrisiken führen kann. In kleinen Institutionen kann die Funktion des ISB auch von einem qualifizierten Mitarbeiter neben anderen Aufgaben wahrgenommen werden. Maßgeblich ist, dass dem ISB ausreichend Zeit für seine Aufgaben zugewillt wird und er in keinem Interessenskonflikt mit anderen Aufgaben steht.

Control: GC.9.1 - Festlegung eines Verfahrens zum Kommunikationsmanagement

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.9 Dokumentation und Kommunikation
UUID: b7947004-8b4e-4b64-b73f-df1e790bed19
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GC.9.1.1 Externer Austausch zur Informationssicherheit
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung

Statement

Governance und Compliance MUSS ein Verfahren zum Kommunikationsmanagement hinsichtlich der internen und externen Kommunikation verankern.

Guidance

Für die relevante Kommunikation im Rahmen eines ISMS sind die Eckpunkte (wer, wann, mit wem, wie) festgelegt. Dies beinhaltet ebenfalls die Identifikation der relevanten Behörden und der relevanten Kontakte sowie die Festlegung von Zuständigkeiten für die Kommunikation.

Control: GC.9.1.1 - Externer Austausch zur Informationssicherheit

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.9 Dokumentation und Kommunikation

Übergeordnetes Control:

GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement

UUID: 4fb02efc-1b80-497d-af10-77433319be96

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance SOLLTE einen externen Austausch zur Informationssicherheit ausführen.

Guidance

Um auch andere Perspektiven wahrzunehmen und Eindrücke zu erhalten, findet ein externer Austausch statt. Hierzu können beispielsweise Branchenverbände, Fachforen oder andere Einrichtungen genutzt werden.

Control: GC.9.1.2 - Kommunikation im Projektmanagement

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.9 Dokumentation und Kommunikation

Übergeordnetes Control:

GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement

UUID: 6ccbc3f1-0984-4b12-86f2-708d40e9b635

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS bei sicherheitsrelevanten Projekten die Beteiligung {{ insert: param, gc.9.1.2-prm1 }} zu festgelegten Zeitpunkten im Projektverlauf verankern.

Guidance

Bei allen Projekten, die Auswirkungen auf die Informationsverarbeitung haben, ist eine frühzeitige Beteiligung des ISB (und ggfs. weiterer sicherheitsrelevanter Organe) von wesentlicher Bedeutung. Beispiele für sicherheitsrelevante Projekte sind die Einführung eines neuen IT-Systems oder einer neuen Software. Beispiele für geeignete Zeitpunkte der Beteiligung sind etwa während der Beschaffung oder vor der Produktivsetzung.

Control: GC.9.1.3 - Dokumentenlenkung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.9 Dokumentation und Kommunikation

Übergeordnetes Control:

GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement

UUID: 9cc14941-253d-4bfa-89f6-8902370cc509

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS ein Verfahren zur Lenkung der Dokumente im Rahmen des ISMS über den kompletten Lebenszyklus von Dokumenten verankern.

Guidance

Ziel eines Verfahrens zur Dokumentenlenkung ist die Sicherstellung der Nachvollziehbarkeit von Dokumenten. Das Verfahren stellt hierbei die Nachvollziehbarkeit über den gesamten Lebenszyklus des Dokuments sicher. Dies beinhaltet die Erstellung bzw. Übernahme (z. B. aus "Alt-Dokumenten" oder externen Dokumenten) der Dokumente mit Titel, Autor, Dokumenteneigentümer, Sicherheitsklassifikation, Erstelldatum sowie einheitlicher Formate. Des Weiteren beinhaltet dies die Steuerung mit einem Änderungsmanagement (Versionierung), einer einheitlichen Veröffentlichung, einer angemessen geschützten Ablage und ggf. auch Archivierung sowie einer Rücknahme.

Control: GC.10.1 - Festlegung von Vorgehensweisen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.10 Festlegung und Freigabe der Vorgehensweise
UUID: 4b2b03f6-103d-4435-9edc-27cd961e2361
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS die Verfahren des ISMS sowie die Zuständigkeiten festlegen.

Guidance

Der Umfang der Dokumentation der Verfahren ist der Größe und Komplexität der Institution angemessen. Die Verfahren beinhalten insbesondere die Risikobetrachtung, die Etablierung von Änderungen im ISMS, die Dokumentenlenkung, die Leistungsbewertung und Auditierung, kontinuierliche Verbesserung sowie reaktive Verfahren (Sicherheitsvorfallbehandlung, Notfallmanagement). In kleineren Institutionen kann dies beispielsweise in einem Dokument erfolgen. In größeren Institutionen kann die Etablierung von Prozessen hierfür erforderlich sein.

Links

related: GC.11.1 Methodik für das Risikomanagement

Control: GC.10.2 - Freigabe von Vorgehensweisen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: GC.10 Festlegung und Freigabe der Vorgehensweise
UUID: d6d44aa6-9010-40f0-9c3b-cc568b951410
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS die Verfahren für das ISMS durch die Institutionsleitung autorisieren.

Guidance

Die Freigabe des Prozesses der ISMS-Verfahren erfolgt durch die Institutionsleitung. Diese Freigabe sollte dokumentiert werden, um Verbindlichkeit und Nachvollziehbarkeit sicherzustellen. Beispielsweise kann diese Freigabe durch die Vorlage eines Managementberichts eingeholt werden

Links

required: GC.10.1 Festlegung von Vorgehensweisen

Control: GC.11.1 - Methodik für das Risikomanagement

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: GC.11 Initiierung des Risikomanagements

UUID: 0567f921-f474-4060-9a64-11e5148ebe09

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Governance und Compliance MUSS eine einheitliche Methodik für das Informationssicherheitsrisikomanagement auf Basis des Kontextes der Institution und der Anforderungen interessierter Parteien sowie der daraus hergeleiteten Risikoziele verankern.

Guidance

Das Risikomanagement stellt sicher, dass Risiken systematisch identifiziert, eingeschätzt, bewertet und behandelt werden. Die Festlegung einheitlicher Kriterien für, Risikoeinschätzung, Risikobewertung und Risikobehandlung, sowie die Rolle des Risikoeigentümers sorgen für Transparenz und Verbindlichkeit. Die Risikomanagementmethodik kann frei gewählt werden. In einem separaten Dokument zur Risikobetrachtung werden verbindliche Vorgaben an die Risikomethodik vorgeschrieben. Die Vorgaben sind entsprechend gängiger Risikomanagement-Prozesse strukturiert.

Links

related: GC.10.1 Festlegung von Vorgehensweisen

Control: PERF.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.1 Leistungsbewertung des ISMS

UUID: 02e914c1-69b6-4baa-a194-3c3c10a417de

Aufwand: 0

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen

Statement

Monitoring-Evaluation MUSS Verfahren und Regelungen zur Messung und Bewertung der Leistung des ISMS verankern.

Guidance

Die bei der Festlegung des Verfahrens und der Regelungen im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik. Die Ergebnisse müssen strukturiert dokumentiert und an die relevanten Stakeholder kommuniziert werden.

Control: PERF.1.1.1 - Auswertung der Gefährdungslage

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.1 Leistungsbewertung des ISMS

Übergeordnetes Control:

PERF.1.1 Verfahren und Regelungen

UUID: 7797cd44-8cc3-4b75-a4b8-9faefe2c16d7

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Gefährdungslage in Bezug auf geänderte Rahmenbedingungen überprüfen.

Guidance

Die Auswertung der Gefährdungslage im Hinblick auf Veränderungen stellt sicher, dass neue oder veränderte Rahmenbedingungen (organisatorischer, technischer oder rechtlicher Art) potenziell zusätzliche Gefährdungen erzeugen und deshalb im ISMS berücksichtigt werden; konkrete Prüfpunkte umfassen technische Veränderungen wie die Einführung neuer IT-Systeme, Software, Netzwerktechnologien oder Cloud-Dienste, organisatorische Veränderungen wie Outsourcing, neue Standorte, Umstrukturierungen sowie veränderte Schnittstellen oder Verantwortlichkeiten, rechtliche und regulatorische Änderungen wie neue Gesetze (z. B. NIS2, Anpassungen der DSGVO) und Branchenvorgaben, die zusätzliche Compliance-Risiken begründen, sowie eine veränderte Bedrohungslage durch neue Angriffsarten, aktuelle Sicherheitsvorfälle und CERT-Warnungen, was eine Aktualisierung der Gefährdungskataloge erforderlich machen kann; daraus folgen eine regelmäßige Überprüfung der Gefährdungslage (z. B. halbjährlich oder anlassbezogen), die Anpassung der Risikobetrachtung bei identifizierten neuen Gefährdungen, die Ableitung neuer Schutzmaßnahmen bzw. die Nachbesserung bestehender sowie die nachvollziehbare Dokumentation von Prüfungen und Ergebnissen im ISMS.

Control: PERF.1.1.2 - Auswertung des Umsetzungsplans

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.1 Leistungsbewertung des ISMS

Übergeordnetes Control:

PERF.1.1 Verfahren und Regelungen

UUID: ffabec9a-1a60-4edc-bdbb-adc79c43d7c8

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE den Umsetzungsplan in Bezug auf den Fortschritt, die Einhaltung von Fristen und der inhaltlichen Korrektheit {{ insert: param, perf.1.1.2-prm1 }} überprüfen.

Guidance

Die Überprüfung eines Umsetzungsplans beinhaltet, ob Sicherheitsmaßnahmen vollständig, termingerecht und wirksam sowie inhaltlich korrekt umgesetzt wurden und ob sie die angestrebten Schutzziele erreichen. Dabei sind insbesondere der Umsetzungsstand, Abweichungen, Restrisiken und die Wirksamkeit der Maßnahmen systematisch zu überprüfen und für Managemententscheidungen auszuwerten. Umsetzungsdaten umfassen z. B. Fälligkeitsdatum, bis wann eine bestimmte Maßnahme umgesetzt sein muss, Meilensteine im Projektplan oder vereinbarte Endtermine für Kontrollen, Prüfungen oder technische Implementierungen.

Control: PERF.1.1.3 - Auswertung von Auditergebnissen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.1 Leistungsbewertung des ISMS

Übergeordnetes Control:

PERF.1.1 Verfahren und Regelungen

UUID: cc351e72-c510-4df1-9224-b7867aa8a39e

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Umsetzung von festgelegten Maßnahmen aus Auditergebnissen überprüfen.

Guidance

Die Auswertung von Auditergebnissen dient dazu, systematische Abweichungen, Schwachstellen und Verbesserungspotenziale im Informationssicherheitsmanagement zu identifizieren. Im Audit festgestellte Abweichungen, Hinweise und Empfehlungen werden ausgewertet, nach ihrer Bedeutung geordnet und in konkrete Maßnahmen überführt. Diese Maßnahmen werden anschließend überwacht und ihre Umsetzung nachverfolgt.

Control: PERF.1.1.4 - Auswertung von Sicherheitsvorfällen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.1 Leistungsbewertung des ISMS

Übergeordnetes Control:

PERF.1.1 Verfahren und Regelungen

UUID: 210472b2-d941-421f-ba5d-0a62eb8e8cf0

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE umgesetzte Maßnahmen als Folge von Sicherheitsvorfällen überprüfen.

Guidance

Bei der Auswertung von Sicherheitsvorfällen sollten Ursachen, Auswirkungen, Reaktionen und Schwachstellen systematisch analysiert werden, um gezielte Verbesserungsmaßnahmen abzuleiten. Wichtig ist, dass sowohl die Wirksamkeit der Sofortmaßnahmen als auch die Umsetzung und Nachhaltigkeit der Folgemaßnahmen überprüft werden.

Control: PERF.2.1 - Überwachung der Einhaltung von Verpflichtungen

Tag: "Compliance-Management"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.2 Überwachung der Compliance

UUID: 9bb16672-4394-4ce9-bd14-12a080233f7a

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Einhaltung von Verpflichtungen {{ insert: param, perf.2.1-prm1 }} sowie anlassbezogen überprüfen.

Guidance

Im Rahmen der Compliance-Überwachung sollte die Einhaltung von Verpflichtungen regelmäßig sowie anlassbezogen überprüft werden. Dies umfasst regelmäßige Kontrollen zur Überprüfung der Einhaltung dokumentierter gesetzlicher und vertraglicher Anforderungen, anlassbezogene Überprüfungen bei Änderungen des regulatorischen Umfelds, bei Hinweisen auf mögliche Verstöße oder nach durchgeführten Änderungen in relevanten Systemen oder Prozessen, die Identifikation von Compliance-Lücken und deren systematische Dokumentation sowie die Entwicklung und Umsetzung von Maßnahmen zur Schließung identifizierter Compliance-Lücken.

Links

related: GC.7.1 Verfahren und Regelungen

related: UMS.7.1 Wahrung von Compliance in der Umsetzung

Control: PERF.3.1 - Aufbau und Pflege eines Auditprogramms

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: PERF.3 Auditprogramm und -durchführung
UUID: 26cebd96-ae1b-46e8-9d1c-95f969b769dc
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.3 Auswahl des Auditteams
- PERF.3.1.4 Umfang von Audits

Statement

Monitoring-Evaluation MUSS ein Verfahren zum Aufbau und zur Pflege eines oder mehrerer Auditprogramme verankern.

Guidance

Ein Audit kann in unterschiedlichen Formen durchgeführt werden – beispielsweise als internes Audit durch eigene Mitarbeitende, als externes Audit durch unabhängige Dritte (z. B. für Zertifizierungen), als Überwachungs- oder Wiederholungsaudit, oder als Sonderaudit bei Sicherheitsvorfällen. Ziel ist es, die Einhaltung von Sicherheitsanforderungen, die Wirksamkeit von Maßnahmen sowie mögliche Schwachstellen zu prüfen.

Control: PERF.3.1.1 - Erstellen eines Auditsplans

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.3 Auditprogramm und -durchführung

Übergeordnetes Control:

PERF.3.1 Aufbau und Pflege eines Auditprogramms

UUID: e81de2b1-c4fd-47b7-86a6-f858db31306e

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE für jedes durchzuführende Audit einen Auditplan festlegen.

Guidance

Der Auditplan (audit plan) legt vorab die Ziele, den Umfang (Geltungsbereich, Zielobjekte), die Methoden (Auditkriterien), Rollen und Zuständigkeiten, sowie den genauen Ablauf dieser Überprüfung fest. Auditmethoden sind die spezifischen Vorgehensweisen und Techniken, die ein Auditor zur Sammlung und Bewertung von Prüfungsnachweisen (audit evidence) einsetzt. Die Auswahl der Methode hängt vom jeweiligen Prüfziel ab und umfasst häufig eine Kombination aus mehreren Ansätzen, wie zum Beispiel: (1) die Befragung von Mitarbeitern (Interviews), um Prozessabläufe und Verantwortlichkeiten zu verstehen, (2) die (automatisierte und manuelle) Durchsicht von Dokumenten wie Richtlinien, Konzepten und Protokollen zur Überprüfung der Vorgabenkonformität, (3) die direkte Beobachtung von Prozessen, um die tatsächliche Umsetzung einer Kontrolle zu verifizieren, sowie (4) technische Analysen, welche die Überprüfung von Systemkonfigurationen, die Auswertung von Logdateien oder die Durchführung von Stichproben bei Berechtigungen beinhalten können. Der Zweck dieser Anforderung ist es, eine strukturierte und nachvollziehbare Vorgehensweise bei jeder Prüfung zu gewährleisten. Ohne einen solchen Plan könnte eine Überprüfung chaotisch verlaufen, wichtige Bereiche übersehen oder Ressourcen ineffizient eingesetzt werden, was unentdeckte Schwachstellen zur Folge haben kann. Ein detaillierter Auditplan kann hingegen sicherstellen, dass alle relevanten Aspekte systematisch abgedeckt werden und schafft eine klare Erwartungshaltung sowie Verbindlichkeit für die Auditoren und die geprüften Stellen der Institution. Bewährt hat sich dabei eine chancen- und risikenorientierte Ressourcenverteilung, d.h. die

Betrachtung genau jener Anforderungen, bei denen voraussichtlich ein hoher Mehrwert für die Risikobetrachtung durch das Audit zu erwarten ist. Für Details siehe ISO/IEC 19011-Reihe. Der Plan muss dokumentiert werden.

Control: PERF.3.1.2 - Planen von internen Audits

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.3 Auditprogramm und -durchführung

Übergeordnetes Control:

PERF.3.1 Aufbau und Pflege eines Auditprogramms

UUID: 6f76ca8f-aadb-44b2-89ce-c35ac8a16d69

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS die Planung der internen Audits im Auditprogramm risikoorientiert ausführen.

Guidance

Ziel ist es, die Einhaltung von Sicherheitsanforderungen, die Wirksamkeit von Maßnahmen sowie mögliche Schwachstellen zu prüfen. Dabei wird die Effektivität und Effizienz aller angewandten Anforderungen sinnvoll geprüft. Risikoorientiert bedeutet hierbei, dass die Auswahl von Prüfobjekten sowie die Prüftiefe sich nach einer Risikobetrachtung richtet, also besonders risikorelevante Fragen vertieft betrachtet werden. Beispielsweise ist es sinnvoll bei automatisierten Richtlinien (Policies) nicht nur deren tatsächliche Aktivierung, sondern vor allem die erlaubten Ausnahmeregelungen auf Begründung, Befristung und Umfang zu prüfen, damit vermeintliche effektive Maßnahmen nicht durch zu weite Ausnahmeregelungen ausgehöhlt werden. Die Planung muss dokumentiert werden.

Control: PERF.3.1.3 - Auswahl des Auditteams

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.3 Auditprogramm und -durchführung

Übergeordnetes Control:

PERF.3.1 Aufbau und Pflege eines Auditprogramms

UUID: 9c848e6f-ba7e-49de-9655-e95c57acafa3

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS fachlich geeignete und unabhängige Auditoren zur Gewährleistung der Objektivität und Qualität der Audits anweisen.

Guidance

Bei der Auswahl von Auditoren ist zu empfehlen insbesondere Fachkompetenz, Unabhängigkeit und Erfahrung zu berücksichtigen. Das Team muss über technisches und organisatorisches Wissen, Kenntnisse relevanter Normen und gesetzliche Anforderungen sowie die Fähigkeit zur objektiven, methodischen Bewertung verfügen, ohne in die zu prüfenden Prozesse direkt involviert zu sein.

Control: PERF.3.1.4 - Umfang von Audits

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.3 Auditprogramm und -durchführung

Übergeordnetes Control:

PERF.3.1 Aufbau und Pflege eines Auditprogramms

UUID: dd98f0ad-e27d-44dd-8a44-1fee1657b714

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS in angemessenem Umfang Audits ausführen.

Guidance

Der Umfang eines Audits beschreibt, was, wie und in welchem Rahmen geprüft wird. Dazu gehören der organisatorische und technische Geltungsbereich (z. B. Standorte, Abteilungen, IT-Systeme), der Prüfzeitraum, sowie die eingesetzten Prüfmethode wie Interviews, Dokumentensichtung oder Systemtests. Der Auditumfang wird vor Beginn des Audits klar definiert, um den Ablauf gezielt zu planen und die Ergebnisse nachvollziehbar zu dokumentieren.

Control: PERF.4.1 - Dokumentation von Auditergebnissen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: PERF.4 Bewertungsschema und Auditberichte
UUID: d173c0e0-9c22-414c-b4c8-633c7a75a406
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.4.1.2 Kommunikation an Stakeholder

Statement

Monitoring-Evaluation MUSS ein Verfahren zur Erstellung aussagekräftiger Auditberichte verankern.

Guidance

Ein Auditbericht muss nachvollziehbar, vollständig und strukturiert dokumentieren, wie das Audit durchgeführt wurde und welche Ergebnisse erzielt wurden. Er enthält Angaben zum Auditziel, Auditumfang, Auditteam, Auditmethoden, den bewerteten Bereichen sowie eine übersichtliche Darstellung der Feststellungen inklusive Abweichungen, Verbesserungspotenzialen und der Bewertung der Wirksamkeit der umgesetzten Sicherheitsmaßnahmen. Die Auditberichte sollten neben den identifizierten Schwachstellen auch positive Feststellungen enthalten, um ein ausgewogenes Bild zu vermitteln und Best Practices zu fördern.

Links

related: PERF.3.1 Aufbau und Pflege eines Auditprogramms

Control: PERF.4.1.1 - Einheitliches Bewertungsschema

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.4 Bewertungsschema und Auditberichte

Übergeordnetes Control:

PERF.4.1 Dokumentation von Auditergebnissen

UUID: cbd3ce59-8979-4ae0-a6ee-f0779d9a2598

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE für Feststellungen in Audits ein einheitliches Bewertungsschema festlegen.

Guidance

Das Bewertungsschema soll die einheitliche Bewertung, die Wirksamkeit der Auditprozesse und die Vergleichbarkeit von Auditergebnissen sicherstellen.

Links

related: PERF.3.1 Aufbau und Pflege eines Auditprogramms

Control: PERF.4.1.2 - Kommunikation an Stakeholder

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.4 Bewertungsschema und Auditberichte

Übergeordnetes Control:

PERF.4.1 Dokumentation von Auditergebnissen

UUID: 3f9935bd-65fa-4212-a7e7-726f39933c7d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS eine angemessene Kommunikation an alle relevanten Stakeholder ausführen.

Guidance

Eine angemessene Kommunikation der Auditergebnisse an alle relevanten Stakeholder muss sichergestellt werden, um das Bewusstsein für identifizierte Risiken zu schärfen und die Umsetzung von Verbesserungsmaßnahmen zu fördern.

Links

related: PERF.3.1 Aufbau und Pflege eines Auditprogramms

Control: PERF.5.1 - Eignungsprüfung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

UUID: f9cf8bd8-9a68-4294-9e33-ab7b4f28c68c

Aufwand: 0

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge

Statement

Monitoring-Evaluation MUSS das ISMS der Institution hinsichtlich Eignung, Angemessenheit und Wirksamkeit {{ insert: param, perf.5.1-prm1 }} sowie anlassbezogen überprüfen.

Guidance

Damit die Institutionsleitung fundierte Entscheidungen zur Steuerung des Informationssicherheitsprozesses treffen kann, ist ein prägnanter Managementbericht erforderlich. Darin werden die wesentlichen Eckpunkte zum Stand der Informationssicherheit übersichtlich aufbereitet. Der Bericht SOLL: kurz, klar und verständlich sein, relevante Informationen bzw. Entwicklungen enthalten, nicht überfrachtet sein d.h. den Fokus auf das Wesentliche legen. So kann die Leitung gezielt Maßnahmen priorisieren und Ressourcen effektiv einsetzen. Es muss unter anderem deutlich werden, ob der beabsichtigte Sicherheitszweck wirksam erfüllt wird.

Control: PERF.5.1.1 - Ergebnisse von Folgemaßnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: 917cda33-b472-4526-bdee-db022ffa506c

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der den Status von Folgemaßnahmen vorangegangener Managementbewertungen enthält, dokumentieren.

Guidance

Die Evaluierung von Folgemaßnahmen früherer Managementbewertungen dient der Prüfung, ob geplante Maßnahmen umgesetzt und ihre Ziele erreicht wurden. Dabei müssen Status, Wirksamkeit und mögliche Abweichungen nachvollziehbar dokumentiert und in die aktuelle Managementbewertung eingebunden werden. Die Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.2 - Geänderte Rahmenbedingungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: a45c5319-e786-4c30-868e-84416d2f0fe4

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der geänderte Rahmenbedingungen mit Auswirkungen auf das Informationssicherheitsmanagement berücksichtigt, dokumentieren.

Guidance

Die Ergebnisse der Überprüfung der Rahmenbedingungen – wie rechtliche, organisatorische, technische oder wirtschaftliche Veränderungen – müssen systematisch erfasst und auf ihre Auswirkungen auf das ISMS bewertet werden. Relevante Änderungen sind in der Managementbewertung einzubeziehen, da sie Einfluss auf die Risikobetrachtung und erforderliche Anforderungen bzw. Sicherheitsmaßnahmen haben können. Die Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.3 - Erfolge und Probleme

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: 3111f074-e762-4bf0-b0b4-3d548e27cef5

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der bisherige Erfolge und Probleme (z. B. Sicherheitsvorfälle) beim Informationssicherheitsprozess berücksichtigt, dokumentieren.

Guidance

Die Ergebnisse müssen im ISMS-Prozess berücksichtigt werden, um daraus gezielte Verbesserungen abzuleiten. Sie dienen als wichtige Eingaben für die Managementbewertung und unterstützen die Weiterentwicklung der Sicherheitsstrategie. Zu Erfolgen zählen z. B. wirksam umgesetzte Maßnahmen, erreichte Sicherheitsziele, erfolgreiche Audits/Prüfungen oder eine nachweisbare Reduktion von Risiken. Die Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.4 - Interne Überprüfungen und Audits

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: 15f611e0-cd25-4dec-b757-9d46e5c6b0e6

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Ergebnisse interner Überprüfungen und Audits enthält, dokumentieren.

Guidance

Bei der Evaluierung müssen die Ergebnisse interner Überprüfungen und Audits dokumentiert werden, um festzustellen, ob das ISMS wirksam umgesetzt und aufrechterhalten wird. Dabei sind insbesondere identifizierte Abweichungen, Verbesserungspotenziale und umgesetzte Korrekturmaßnahmen nachvollziehbar darzustellen. Die Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.5 - Eignungsprüfung bisheriger Sicherheitsmaßnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: 85b88ff7-5d53-43cc-b824-2b55d6635386

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der eine Bewertung enthält, ob sich die Sicherheitsmaßnahmen zur Erreichung der Sicherheitsziele als geeignet erwiesen haben oder ob Maßnahmen geändert oder ergänzt werden müssen, dokumentieren.

Guidance

Zur Bewertung, ob Sicherheitsmaßnahmen zur Erreichung der Sicherheitsziele geeignet sind, müssen die Maßnahmen systematisch den jeweiligen Zielen zugeordnet und ihre Wirksamkeit anhand konkreter Nachweise (z. B. Auditergebnisse, Vorfallanalysen, Tests) überprüft werden. Werden Defizite festgestellt, sind die Maßnahmen entsprechend anzupassen, zu ergänzen oder durch geeignetere zu ersetzen. Die Ergebnisse dieser Überprüfung sind nachvollziehbar zu dokumentieren und in den Managementbericht einzubringen und basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.6 - Rückmeldung von Stakeholdern

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: 65fd515e-d390-49f5-87b4-68aaaf392e9f

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Rückmeldungen von Kunden, Geschäftspartnern, Mitarbeitern oder der Öffentlichkeit zu Sicherheitsaspekten bei der Bewertung berücksichtigt, dokumentieren.

Guidance

Betroffene Personen wie z. B. Kunden, Geschäftspartner und die Öffentlichkeit sollen aktiv zu Sicherheitsaspekten befragt oder deren Feedback systematisch erfasst werden, z. B. über Umfragen, Beschwerden, Supportanfragen oder öffentliche Bewertungen. Dieses Feedback ist auf Relevanz und Auswirkungen für das ISMS zu prüfen, zu dokumentieren und bei Bedarf in Risikobetrachtungen und Verbesserungsmaßnahmen einzubeziehen. Verantwortliche müssen sicherstellen, dass Rückmeldungen zeitnah ausgewertet und bei der Weiterentwicklung der Sicherheitsmaßnahmen berücksichtigt werden. Die Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.7 - Status des Realisierungsplans

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: d24f550c-1502-4587-899b-5e7594363419

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der Berichte über die Reduzierung bestehender Umsetzungsdefizite und der damit verbundenen Risiken (Status des Realisierungsplans) dokumentieren.

Guidance

Die Überprüfung von Umsetzungsdefiziten und Risiken ist im ISMS ein zentraler Bestandteil des Monitorings und der Evaluierung. Monitoring sorgt für die kontinuierliche Beobachtung des Fortschritts bei Maßnahmenumsetzung, während die Evaluierung die Wirksamkeit dieser Maßnahmen bewertet und bei Bedarf Anpassungen empfiehlt. So wird sichergestellt, dass Risiken nachhaltig reduziert und Sicherheitsziele erreicht werden. D. h. der Status des Realisierungsplans muss fortlaufend überprüft werden. Die Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.8 - Verbesserungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: f591a6d1-19bc-4b0d-8d4d-48f9afa67e40

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation SOLLTE die Ergebnisse dieser Überprüfungen in einem Managementbericht, der die Ergebnisse der Bewertung in Form von Verbesserungen in das ISMS einfließen lässt, dokumentieren.

Guidance

Hier ist zu dokumentieren, 1. ob identifizierte Verbesserungsmaßnahmen tatsächlich umgesetzt wurden (z.B. Änderungen an Prozessen, technische Anpassungen, Schulungen). 2. in welcher Form diese Maßnahmen ins ISMS eingeflossen sind, also ob sie dokumentiert, in der Risikobetrachtung berücksichtigt und in den Steuerungsprozessen verankert wurden. 3. ob die Verbesserungen die angestrebte Wirkung zeigen, also zur Reduzierung von Risiken oder zur Erreichung der Sicherheitsziele beitragen. 4. ob die Maßnahmen dauerhaft aufrechterhalten und kontinuierlich überwacht werden, um nachhaltige Verbesserungen sicherzustellen. Die Ergebnisse dieser Evaluierung sind nachvollziehbar zu dokumentieren und bilden die Grundlage für weitere Entscheidungen im Rahmen des kontinuierlichen Verbesserungsprozesses und basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.1.9 - Maßnahmvorschläge

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

Übergeordnetes Control:

PERF.5.1 Eignungsprüfung

UUID: c6ecb13d-2c6a-495d-89fd-8d9e699b3ff9

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS die Ergebnisse dieser Überprüfungen in einem Managementbericht, der priorisierte Maßnahmvorschläge mit realistischen Abschätzungen zum erwarteten Umsetzungsaufwand enthält, dokumentieren.

Guidance

Maßnahmvorschläge müssen daraufhin überprüft werden, ob sie wirksam zur Risikoreduktion beitragen und mit vertretbarem Aufwand umsetzbar sind. Dabei sind Nutzen, Kosten, technischer und organisatorischer Aufwand realistisch abzuschätzen und in Relation zueinander zu bewerten, um fundierte Entscheidungen zur Umsetzung und Priorisierung treffen zu können. Die Ergebnisse dieser Überprüfungen basieren auf den vorab erstellten Auditberichten sowie der geforderten Eignungsprüfung.

Control: PERF.5.2 - Bericht an die Institutionsleitung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.5 Managementbewertungen

UUID: 5d8dcc2-5fea-43c1-a804-0b49f481a1ca

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS die Institutionsleitung über den Stand des Managementsystems {{ insert: param, perf.5.2-prm1 }} anhand des Managementberichtes informieren.

Guidance

Sinn und Zweck der Anforderung liegt darin, die Leitungsebene regelmäßig und nachvollziehbar über den Sicherheitsstatus sowie über wesentliche Entwicklungen zu informieren. Damit kann die Leitung faktenbasiert Entscheidungen treffen, Prioritäten setzen und Ressourcen zielgerichtet bereitstellen. Ohne einen solchen Bericht könnte ein kritisches Risiko unbemerkt bleiben oder verspätet adressiert werden, etwa wenn wiederholt unbefugte Zugriffe auf sensible Daten auftreten. Ein gut aufbereiteter Bericht kann hingegen Transparenz schaffen, Verantwortlichkeiten verdeutlichen und Vertrauen in die Steuerung der Institution fördern. Zur Umsetzung ist ein fester Rhythmus für die Erstellung des Managementberichts zu etablieren, etwa quartalsweise oder anlassbezogen nach einem schweren Vorfall. Der Bericht kann eine verdichtete Darstellung enthalten, zum Beispiel in Form von übersichtlichen Kennzahlen (Anzahl relevanter Vorfälle, Zeit bis zur Entdeckung, Erfüllungsgrad definierter Sicherheitsmaßnahmen) und Trendanalysen. Ergänzend kann eine einheitliche Vorlage genutzt werden, die eine klare Struktur vorgibt, sodass die Leitungsebene schnell die entscheidenden Punkte erkennt. Technisch kann dies durch den Einsatz gängiger Office-Tools unterstützt werden, etwa durch die Visualisierung von Trends in Diagrammen. Prozessual können Rückfragen und Diskussionen in einer kurzen Managementrunde eingeplant werden, um den reinen Informationsfluss zu einem aktiven Austausch zu machen.

Links

required: PERF.5.1 Eignungsprüfung

Control: PERF.6.1 - Sicherheitsvorfälle

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: PERF.6 Monitoringmethoden und -tools
UUID: 17e221bd-3b74-453a-ad4e-e2cb346b6af5
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERF.6.1.1 Sicherheitsvorfälle
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen

Statement

Monitoring-Evaluation MUSS effektive Monitoring-Methoden und -tools zur {{ insert: param, perf.6.1-prm1 }} Überwachung der Informationssicherheit verankern.

Guidance

Die Implementierung von Monitoring-Methoden und -tools sollte an die individuellen Bedürfnisse und Möglichkeiten der Institution angepasst sein. Während kleinere Institutionen mit einfacheren Lösungen arbeiten können, benötigen größere und komplexere Umgebungen oft umfassendere und stärker automatisierte Ansätze. Die gewonnenen Monitoring-Daten sollten systematisch ausgewertet und für verschiedene Zwecke genutzt werden, darunter die Erstellung von Kennzahlen und Berichten, die Früherkennung von Sicherheitsrisiken, die Unterstützung der Incident Response und die kontinuierliche Verbesserung des ISMS. Beispielhafte Tools für die Überwachung von Informationssicherheit sind Security Information and Event Management (SIEM) Systeme für die zentrale Sammlung, Korrelation und Analyse von Sicherheitsereignissen aus verschiedenen Quellen; Intrusion Detection/Prevention Systeme (IDS/IPS) zur Erkennung und Abwehr verdächtiger Netzwerkaktivitäten; Vulnerability Management Systeme zur systematischen Identifikation und Behandlung von Schwachstellen sowie Configuration Monitoring Tools zur Überwachung von Konfigurationsänderungen in Systemen und Anwendungen.

Control: PERF.6.1.1 - Sicherheitsvorfälle

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.6 Monitoringmethoden und -tools

Übergeordnetes Control:

PERF.6.1 Sicherheitsvorfälle

UUID: 3c76f9bf-7a52-4ba4-a9dd-f351e543ca9f

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS Sicherheitsvorfälle überwachen.

Guidance

Die frühzeitige Identifikation und Meldung von Vorfällen muss ermöglicht werden. Dies kann von manuellen Prozessen bis hin zu automatisierten Erkennungssystemen reichen. Es sollen klare Meldewege, technische Überwachungsmechanismen (z. B. Log-Analyse, Intrusion Detection), Verantwortlichkeiten sowie Kriterien zur Klassifikation von Vorfällen vorliegen. So wird gewährleistet, dass sicherheitsrelevante Ereignisse frühzeitig erkannt, bewertet und in den ISMS-Verbesserungsprozess eingebunden werden.

Control: PERF.6.1.2 - Schwachstellen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.6 Monitoringmethoden und -tools

Übergeordnetes Control:

PERF.6.1 Sicherheitsvorfälle

UUID: 4f185314-4f6f-4539-b14e-d230c84ecd4d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS einen Umgang mit Schwachstellen festlegen.

Guidance

Dies sollte die systematische Identifikation, Bewertung, Behandlung und Nachverfolgung von Schwachstellen umfassen. Schwachstellen müssen systematisch erfasst, auf ihre sicherheitsrelevante Bedeutung geprüft und in die Risikobetrachtung des ISMS übernommen werden. Daraus abgeleitete Maßnahmen sind zu priorisieren, umzusetzen und im Rahmen des Monitorings und der Evaluierung regelmäßig auf ihre Wirksamkeit hin zu überprüfen sowie zu dokumentieren. Die gewonnenen Monitoring-Daten sollten systematisch ausgewertet und für verschiedene Zwecke genutzt werden, darunter die Erstellung von Kennzahlen und Berichten, die Früherkennung von Sicherheitsrisiken, die Unterstützung der Incident Response und die kontinuierliche Verbesserung des ISMS.

Control: PERF.6.1.3 - Bedrohungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.6 Monitoringmethoden und -tools

Übergeordnetes Control:

PERF.6.1 Sicherheitsvorfälle

UUID: 4599c41b-8c08-46cc-a88d-3a2ab141994c

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS einen Umgang zur Erkennung und Reaktion auf neu auftretende Bedrohungen festlegen.

Guidance

Ein Verfahren zur Erfassung und Reaktion neu auftretende Bedrohungen stellt sicher, dass diese mit Beschreibung und Bewertung dokumentiert werden; dass die Risikobetrachtung bei Bedarf aktualisiert wird; eine Neubestimmung von Eintrittswahrscheinlichkeit und Schadensausmaß erfolgt; dass geeignete Gegenmaßnahmen abgeleitet werden; die Risiken priorisiert und mit klaren Verantwortlichkeiten versehen werden; dass die neuen Risiken in bestehende Risikobetrachtungsprozesse integriert werden und dass das Management regelmäßig über die aktuelle Risikolage und die Wirksamkeit der umgesetzten Maßnahmen unterrichtet wird.

Control: PERF.7.1 - Aktualität der Anforderungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: PERF.7 Validierung der Anforderungen

UUID: 1d6e2d9d-a9b9-46cb-9079-a2587c90c661

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Monitoring-Evaluation MUSS die Aktualität der Anforderungen {{ insert: param, perf.7.1-prm1 }} überprüfen.

Guidance

Die Verifikation sollte folgende Aspekte umfassen: Das Anforderungspaket sollte regelmäßig (i.A. jährlich, je nach Organisationsgröße, Parameter und Prüftiefe) in Hinblick auf die Modellierung überprüft werden, um ihre Aktualität und Angemessenheit in Bezug auf den Informationsverbund zu bewerten. Bei der Überprüfung sollten veränderte Geschäftsprozesse, neue IT-Komponenten, organisatorische Änderungen und externe Faktoren wie neue regulatorische Anforderungen oder veränderte Bedrohungslandschaften berücksichtigt werden. Die Überprüfung sollte in Abstimmung mit den zuständigen Bereichen erfolgen, um sicherzustellen, dass alle relevanten Perspektiven einbezogen werden. Bei Bedarf sollten Anpassungen der Auswahl der Anforderungen vorgenommen werden, um den aktuellen Anforderungen gerecht zu werden. Wenn signifikante Anpassungen erforderlich sind, können diese zu einer Neumodellierung oder Erweiterung des Anforderungspakets führen, was wiederum den gesamten Zyklus der Strukturmodellierung und Umsetzung beeinflusst. Die Verifikation sollte dokumentiert werden.

Control: STM.1.1 - Definition und Abgrenzung des Informationsverbunds

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.1 Definition und Abgrenzung des Informationsverbunds

UUID: cba2f75c-95f5-4398-9a8b-7773bdcd1c7d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS den nachvollziehbar abgegrenzten Informationsverbund auf Basis des Geltungsbereichs festlegen.

Guidance

Definieren und dokumentieren Sie den Informationsverbund. Dieser bildet den Geltungsbereich inhaltlich-technisch ab und umfasst die informationsverarbeitenden Systeme, Prozesse und Komponenten, die innerhalb des festgelegten Geltungsbereichs betrachtet werden. Dokumentieren Sie, welche Institutionsbereiche, Rollen und Personen zum Informationsverbund gehören für die organisatorische Abgrenzung. Grenzen Sie zusätzlich aus technischer Perspektive ab, welche Anwendungen, Systeme und Netze Bestandteil Ihres Informationsverbundes sind. Dokumentieren Sie weiterhin, welche Betriebsanteile an externe Parteien outgessourced - bsw. welche Cloud-Dienste genutzt - werden. In der Praxis kann es in einem Geltungsbereich auch mehrere Informationsverbünde geben.

Links

required: GC.4.1 Festlegung des Geltungsbereichs

Control: STM.1.2 - Dokumentation der externen Schnittstellen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.1 Definition und Abgrenzung des Informationsverbunds

UUID: c30d414e-65e5-460e-8239-892f9a196a1f

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS Schnittstellen des Informationsverbunds zu externen Prozessen festlegen.

Guidance

Im Informationsverbund sind die organisatorischen, technischen und infrastrukturellen Schnittstellen dargestellt. Für eine eindeutige Abgrenzung sind im Informationsverbund die Schnittstellen definiert. Wie bei der Beschreibung des Informationsverbunds selbst, sind auch hier organisatorische, technische sowie infrastrukturelle Schnittstellen berücksichtigt.

Links

required: STM.1.1 Definition und Abgrenzung des Informationsverbunds

Control: STM.2.1 - Erstellung eines Anforderungspakets

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.2 Erstellung eines Anforderungspakets
UUID: c6fb5790-0490-48b6-b409-286915a08353
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS in ein zu erstellendes Anforderungspaket alle Anforderungen die für den betrachteten Informationsverbund relevant sind platzieren.

Guidance

Das Anforderungspaket enthält alle Anforderungen, die für den betrachteten Informationsverbund und den priorisierten Geschäftsprozesse relevant sind sowie wenn erforderlich zusätzlichen Anforderungen. Diese Anforderung dient der grundsätzlichen Vorgabe ein Anforderungspaket zu erstellen. Weitere Details sind den folgenden Anforderungen dieser Praktik zu entnehmen.

Control: STM.3.1 - ISMS-Anforderungen des Informationsverbundes

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.3 ISMS-Anforderungen des Informationsverbundes

UUID: 92bc2497-1440-4718-b35b-9648b3efc4fd

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS alle Anforderungen der ISMS-Praktiken modelliert auf den vorliegenden Informationsverbund platzieren.

Guidance

Neben den zielobjektgebundenen Anforderungen enthält das Kompendium-GS++ auch Anforderungen ohne explizite Zielobjektzuordnung. Diese werden im Anforderungspaket ergänzend berücksichtigt. Für die Anforderungen der ISMS-Praktiken (GC, STM, PERF, VRB, UMS) gilt dabei Folgendes: Die Anforderungen der ISMS-Praktiken sind übergreifend und keinem einzelnen Zielobjekt zugewiesen. Sie bauen den PDCA-Zyklus des Managementsystems auf und gelten deshalb einmalig für den gesamten Informationsverbund. Alle Anforderungen der ISMS-Praktiken werden ohne weitere Selektion auf den Informationsverbund modelliert. Sie werden als „verbundweite Anforderungen“ im Anforderungspaket geführt, da sie Governance-, Steuerungs-, Kontroll- und Verbesserungsprozesse definieren.

Control: STM.4.1 - Erfassung relevanter Assets

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.4 Asset-Modellierung

UUID: 10e75c93-320b-4d4d-baaa-ed7392b274cf

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS alle relevanten Assets für die betrachteten Geschäftsprozesse modelliert auf den vorliegenden Informationsverbund festlegen.

Guidance

Die Asset-Modellierung ist der zentrale Schritt, um den zuvor festgelegten Informationsverbund strukturiert und nachvollziehbar in sicherheitsrelevante Bestandteile zu zerlegen. Ziel ist es, die für den betrachteten Geschäftsprozess relevanten Assets zu identifizieren, zu dokumentieren und so zu modellieren, dass daraus automatisiert oder manuell passende Anforderungen abgeleitet werden können. Assets sind dabei alle materiellen oder immateriellen Werte, die zur Aufgabenerfüllung und zur Erreichung der Geschäftsziele benötigt werden. Die Asset-Modellierung fokussiert auf jene Assets, die im Rahmen der priorisierten Geschäftsprozesse Informationen verarbeiten, speichern, übertragen oder deren Schutz unterstützen. Relevante Assets können insbesondere Informationswerte, Systeme und Anwendungen (System Assets), Netz- und Kommunikationskomponenten, infrastrukturelle und physische Assets sowie personelle und organisatorische Assets sein

Control: STM.4.2 - Dokumentation relevanter Assets

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.4 Asset-Modellierung
UUID: 9a63c78e-a5bb-4d89-a02f-0cf7abdaba40
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS alle Assets mit Relevanz für die betrachteten Geschäftsprozesse dokumentieren.

Guidance

Für die Dokumentation kann auf vorhandene Assetdaten/-register und digitale erfasste Systemdaten zurückgegriffen werden. Für jedes Asset sollten die eindeutige Bezeichnung/ID, eine kurze Beschreibung des Assets und seines Zwecks, die Zuordnung zu Geschäftsprozessen, der/ die verantwortliche Rolle bzw. Asset-Owner und letztlich ggf. der Standort bzw. logische Einordnung (Netz, Anwendungskontext etc.) sowie vorhandene Abhängigkeiten zu anderen Assets dokumentiert werden.

Links

required: STM.4.1 Erfassung relevanter Assets

Control: STM.4.3 - Mapping des Assets auf die Zielobjektkategorien

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.4 Asset-Modellierung

UUID: 1bd2c7b2-badf-4705-9731-aa8888531708

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS allen relevanten Assets passende Zielobjektkategorien zuweisen.

Guidance

Zielobjektkategorien sind Teile des Informationsverbunds, denen im Rahmen der Modellierung Anforderungen zugeordnet werden können. Zielobjekt können dabei physische und logische Objekte sein. Durch das Mapping werden Assets damit in die Systematik des GS++ überführt. Die Zuordnung erfolgt anhand der Definitionen der Zielobjektkategorien. Für jedes Asset ist zu prüfen, welche Kategorie(n) seine Funktion und seinen Einsatz im Geschäftsprozess am besten abbilden. Ergebnis dieses Schritts ist eine Zielobjekt-Liste je Asset, welche die Grundlage für die spätere Ableitung der Anforderungen bildet.

Control: STM.5.1 - Modellierung der Anforderungen mit Zielobjekt

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.5 Anforderungsmodellierung auf die Assets
UUID: 11fe535b-f1f3-49d2-ab01-65fc651281b5
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS die Modellierung der Anforderung aus den Zielobjektkategorien auf die zugeordneten Assets ausführen.

Guidance

Nun werden die Anforderungen aus dem GS++ auf die identifizierten Zielobjekte modelliert. Gemäß dem Schutzbedarf der Institution für den Geschäftsprozess, werden die Anforderungen für ein entsprechendes Sicherheitsniveau gewählt. Die modellierten Anforderungen bilden das individuelle Anforderungspaket des festgelegten Informationsverbund in Bezug auf den ausgewählten Geschäftsprozess.

Links

required: STM.4.3 Mapping des Assets auf die Zielobjektkategorien
related: STM.5.2 Vererbung von Zielobjektkategorien
related: STM.5.3 Konsolidierung und Redundanzprüfung
related: STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie

Control: STM.5.2 - Vererbung von Zielobjektkategorien

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.5 Anforderungsmodellierung auf die Assets
UUID: 3e96574e-7742-42c4-8ccb-4578bcc2f7b0
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS die Ergänzung der zuvor zugeordneten Zielobjektkategorien um diejenigen Kategorien die in der Zielobjekthierarchie übergeordnet sind ausführen.

Guidance

Anforderungen werden einmalig für die passende Zielobjektkategorie definiert und dann auf alle nachgeordneten Kategorien vererbt. Durch die Vererbung wird es einfacher, den Umsetzungsstand und das Sicherheitsniveau über verschiedene Systeme und Anwendungen hinweg zu erfassen und zu vergleichen. Eine automatisierte Verarbeitung der Vererbungshierarchie kann auch der Umsetzungsaufwand in vielen Fällen erheblich reduzieren, ohne dass Themen außen vor bleiben. Die Vererbung erfolgt entlang der Zielobjekthierarchie: Für jedes zugeordnete Zielobjekt werden alle Elternknoten bis zur Wurzel einbezogen. Die Vererbung ist deterministisch, da die Zielobjekthierarchie fest definiert ist. Eine Automatisierung der Vererbung ist möglich und empfohlen, wenn die Hierarchie maschinenlesbar vorliegt. Beachten Sie, dass die Vererbung dazu führen kann, dass sich Zielobjektkategorien mehrfach ergeben; diese sind konsolidiert zu betrachten, um redundante Anforderungen zu vermeiden. Ergebnis dieses Schritts ist eine vollständige Liste der Zielobjektkategorie je Asset, bestehend aus direkt zugeordneten Zielobjektkategorien und vererbten übergeordneten Zielobjektkategorien. Dieses Set bildet die Grundlage für die Anforderungskonsolidierung und -ergänzung um die Anforderungen ohne Zielobjektkategorie.

Links

related: STM.5.1 Modellierung der Anforderungen mit Zielobjekt

related: STM.5.3 Konsolidierung und Redundanzprüfung

related: STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie

Control: STM.5.3 - Konsolidierung und Redundanzprüfung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.5 Anforderungsmodellierung auf die Assets
UUID: 2bb937c6-f260-4742-a0d3-0fbc87dc37f0
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS eine Konsolidierung und Redundanzprüfung des Anforderungspakets ausführen.

Guidance

Wenn Anforderungen durch mehrere vererbte Zielobjekte identisch auf ein Asset wirken, werden sie nur einmal geführt. So bleibt das Anforderungspaket schlank und umsetzbar. Ergebnis ist pro Asset ein vollständiger Satz an Anforderungen, der alle organisatorischen, technischen, personellen und infrastrukturellen Vorgaben enthält, die zur Erreichung des Sicherheitsniveaus erforderlich sind. Diese Anforderungen ergänzen das Anforderungspaket.

Links

related: STM.5.1 Modellierung der Anforderungen mit Zielobjekt

related: STM.5.2 Vererbung von Zielobjektkategorien

related: STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie

Control: STM.5.4 - Modellierung der Anforderungen ohne Zielobjektkategorie

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.5 Anforderungsmodellierung auf die Assets
UUID: 6fa942b2-8081-4a68-8b37-60ae5e4dc081
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS die Modellierung aller weiteren Anforderungen durchführen, wenn keine Zielobjektkategorie zugeordnet ist.

Guidance

Für jede zielobjektlose Anforderung in den vorliegenden Geschäftsprozessen ist eine Relevanzentscheidung vorzunehmen. Für jede Anforderung ohne Zielobjekt wird entschieden, ob sie für den Geschäftsprozess bzw. die zugehörigen Assets erforderlich ist. Maßstab ist hier wiederum das Sicherheitsniveau sowie die konkrete Nutzung für den Geschäftsprozess. Daraufhin erfolgt eine Zuordnung auf die betroffenen Geschäftsprozesse: Hierbei werden diese Anforderungen auch federführend zuständigen Personen oder Rollen (sog. Prozess-Owner) zugewiesen. Für die vorliegenden Geschäftsprozesse nicht relevante Anforderungen werden aus dem Anforderungspaket gestrichen, was mit einer Begründung, zu dokumentieren ist, um Nachvollziehbarkeit bei einem späteren Audit bzw. Zertifizierung zu sichern.

Links

related: STM.5.1 Modellierung der Anforderungen mit Zielobjekt
related: STM.5.2 Vererbung von Zielobjektkategorien
related: STM.5.3 Konsolidierung und Redundanzprüfung

Control: STM.6.1 - Auf Grund anforderungsloser Assets

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.6 Anforderungsergänzung

UUID: 2806a793-8638-4b0b-9247-22252cae48f6

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS die Ergänzung des Anforderungspakets um Anforderungen für die es keine passenden Anforderungen gibt ausführen.

Guidance

Falls es für Assets oder Themen im GS++ derzeit noch keine Anforderungen gibt, können diese von der Institution erstellt werden. Die Anforderungsmodellierung für Assets ohne Anforderungen umfasst folgende Schritte: Zuerst erfolgt die Identifikation und Dokumentation von Assets, für die es keine Anforderungen im Anforderungskatalog-GS++ gibt. Daraufhin ist nachvollziehbar zu begründen, warum die Anforderungen aus dem Anforderungskatalog-GS++ nicht ausreichen. Dann erfolgt die Erstellung von neuen Anforderungen in Bezug auf die Schutzziele (Vertraulichkeit, Integrität und Verfügbarkeit), für diese Assets. Zuletzt wird das Anforderungspaket um die neuen Anforderungen erweitert. Die Ergebnisse dieser Anforderungsmodellierung sind individuelle und bedarfsgerechte Anforderungen für Assets, für die der Grundschutz++ keine Anforderungen enthält. Diese werden als fester Bestandteil in das Anforderungspaket integriert. Es muss eine Risikobetrachtung in Bezug auf diese neuen Anforderungen durchgeführt werden.

Links

related: STM.6.2 Auf Grund externer Verpflichtungen

Control: STM.6.2 - Auf Grund externer Verpflichtungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.6 Anforderungsergänzung

UUID: b620ab56-c91f-47bc-a8fa-a7a594b7d14b

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS die Ergänzung des Anforderungspakets um Anforderungen für Assets die sich aus dem individuellen Compliance-Umfeld der Institution ergeben ausführen.

Guidance

Dieser Schritt ergänzt das Anforderungspaket, um Anforderungen, die sich aus dem individuellen Compliance-Umfeld der Institution ergeben. Die Integration von externen Compliance-Verpflichtungen stellt sicher, dass alle relevanten gesetzlichen und vertraglichen Pflichten berücksichtigt werden, die erfasst wurden. Hier zu zählen z.B. gesetzliche Verpflichtungen, welche die Verarbeitung von Informationen durch die Institution betreffen oder auch vertragliche Verpflichtungen mit Relevanz für die Informationsverarbeitung.

Links

related: STM.6.1 Auf Grund anforderungsloser Assets

Control: STM.7.1 - Überprüfung des gesetzten Sicherheitsniveaus

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.7 Überprüfung des gesetzten Sicherheitsniveaus
UUID: ba3059a8-7745-451a-9601-f4c19c2b4b87
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS die initiale Einstufung der Sicherheitsniveaus der Anforderungen im Anforderungspaket überprüfen.

Guidance

Durch die Durchführung dieses Prozessschrittes der Anforderungsanalyse für alle Geschäftsprozesse mit normalem Schutzbedarf und somit ohne zusätzlich Risikobetrachtung, erfolgt eine Modellierung der Anforderungen mit einem initialen Sicherheitsniveaus. In diesem Teilschritt der Anforderungsanalyse ist es möglich die initiale Einstellung des Sicherheitsniveaus zu überprüfen und bei Bedarf, auch bei einzelnen Assets, zu ändern. Sollte eine Erhöhung des Sicherheitsniveaus (von ‚normal (SdT)‘ auf ‚erhöht‘) erfolgen so hat dies lediglich Auswirkungen auf die Reihenfolge bei der Umsetzung der Anforderungen. Sollte hingegen eine Verringerung des initialen Sicherheitsniveaus (von ‚erhöht‘ auf ‚normal (SdT)‘) erfolgen, so ist dies mit einer Risikobetrachtung, wie im folgenden Kapitel beschrieben, zu begründen.

Links

related: GC.5.1 Vorgehen bei der Informationssicherheitseinstufung

Control: STM.8.1 - Risikobetrachtung bei fehlenden Anforderungen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: STM.8 Durchführung der Risikobetrachtung

UUID: 42cc5d6f-e4f8-4247-a8fa-f90988af02cb

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS eine Risikobetrachtung für die Assets, für die keine einschlägigen Anforderungen identifiziert werden konnten, oder die einen hohen Schutzbedarf haben ausführen.

Guidance

Es kann Assets geben, die durch die Anforderungen nicht oder nicht vollständig abgebildet bzw. abgesichert werden. Diese sind zu dokumentieren, da für diese eine Risikobetrachtung durchzuführen ist. Im Rahmen dieser Risikobetrachtung werden dann eigene Anforderungen bzw. Maßnahmen identifiziert.

Control: STM.9.1 - Verteilung der führenden Zuständigkeiten

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.9 Gestaltungsentscheidungen
UUID: 613c7ac9-0c3d-4a27-8265-2071aede58c4
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS jeder Anforderung eine zuständige Person oder Rolle für den zugeordneten Prozess zuweisen.

Guidance

Jede Praktik enthält im Abschnitt „Grundlagen“ eine Anforderung zur Zuweisung einer Zuständigkeit zu bestimmten Personen oder Rollen. Durch das Setzen dieser Parameter wird festgelegt, welche Personen oder Rollen die führende Zuständigkeit für den zugeordneten Prozess erhalten. Dies wirkt sich auch auf das Anforderungspaket für Zielobjekte aus: Hier ist die Zuständigkeit für jede Anforderung anhand ihrer Praktik erkennbar.

Links

related: GC.8.1 Verfahren zur Ressourcenplanung

Control: STM.9.2 - Weitere Parameter

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: STM.9 Gestaltungsentscheidungen
UUID: 422b1228-e297-49a5-a3ad-29349c2ca03e
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Strukturmodellierung MUSS Parameter innerhalb einer Anforderung zur automatisierten Prüfung zuweisen.

Guidance

Bei manchen Anforderungen wird es eine Auswahl an möglichen einsetzbaren Werten geben, welche durch andere Normen und Standards vorgegeben sein können.

Control: UMS.1.1 - Ermittlung des Umsetzungsstatus

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: UMS.1 Ermittlung des Umsetzungsstatus

UUID: e2c90fc0-e6e5-4a89-8099-39360b6e8eb9

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS den Umsetzungsstatus der Anforderungen der verschiedenen Praktiken vollständig überprüfen.

Guidance

Der Umsetzungsstatus einer Anforderung kann grundsätzlich nur „umgesetzt“ („ja“) oder „nicht umgesetzt“ („nein“) sein. Eine Anforderung gilt nur dann als umgesetzt, wenn sie selbst sowie alle in Abhängigkeit stehenden Anforderungen umgesetzt sind.

Control: UMS.2.1 - Bewertung des Restrisikos

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: UMS.2 Bewertung fehlender Umsetzungen

UUID: 8b7626ab-3fcf-45bd-a7ba-45705436c909

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Umsetzung SOLLTE das bestehende Restrisiko durch die nicht umgesetzten Anforderungen festlegen.

Guidance

Die Risiken der Nichtumsetzung von Anforderungen können auch konsolidiert werden, um diese für die Institutionsleitung nachvollziehbarer zu machen.

Control: UMS.3.1 - Umsetzungsplanung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: UMS.3 Umsetzungsplanung und Priorisierung

UUID: c179a2e9-4e6e-4115-a85e-d66ac93b00e8

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS ein Verfahren zur Festlegung von Maßnahmen für die Umsetzung der bisher nicht umgesetzten Anforderungen des Anforderungspakets als Ergebnis der Praktik Strukturmodellierung verankern.

Guidance

Das Verfahren ist auf die Organisation abzustimmen. Dabei empfiehlt es sich zu prüfen, ob Maßnahmen etabliert sind, die mehrere Anforderungen zugleich abdecken. Ebenso kann das Verfahren genutzt werden, um Synergieeffekte zu erschließen, indem ähnliche Defizite in anderen Bereichen identifiziert und mit gemeinsamen Lösungen adressiert werden.

Control: UMS.3.2 - Priorisierung von Maßnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: UMS.3 Umsetzungsplanung und Priorisierung
UUID: 03f6a09f-5be8-405f-a7b5-4f4fd7034413
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS eine Priorisierung der festgelegten Maßnahmen auf Basis der der Risikobewertung, Abhängigkeiten und Ressourcenverfügbarkeit festlegen.

Guidance

Es ist eine geeignete Priorisierung der Anforderungen und Maßnahmenumsetzung vorzunehmen. Gesetzliche Verpflichtungen und Compliance, der Umsetzungsaufwand einer Anforderung bzw. Maßnahme oder die Risikomitigierung der Anforderungen können bei der Priorisierung helfen.

Links

required: UMS.3.1 Umsetzungsplanung

Control: UMS.4.1 - Benennung von Umsetzungszuständigen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: UMS.4 Zuständigkeiten und Umsetzungsfristen
UUID: 0ea195d5-64a3-4c83-84a4-7acb976a0f26
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS Zuständige für die Umsetzung der bisher nicht erfüllten Anforderungen eindeutig zuweisen.

Guidance

Die Zuständigen für die Umsetzung der Priorisierungen müssen eindeutig zugewiesen werden, wobei die zugewiesenen Personen oder Teams über die erforderlichen Kompetenzen und Ressourcen verfügen sollten. Die Zuweisung von Zuständigkeiten sollte in Abstimmung mit den betroffenen Bereichen erfolgen, um Akzeptanz und Commitment zu fördern. Insbesondere bei komplexeren Maßnahmen kann es sinnvoll sein, sowohl eine fachliche als auch eine operative Verantwortung zu definieren und bei Bedarf Teilaufgaben mit eigenen Verantwortlichkeiten zu bilden

Links

related: UMS.3.1 Umsetzungsplanung

Control: UMS.4.2 - Festlegung von Umsetzungsfristen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: UMS.4 Zuständigkeiten und Umsetzungsfristen
UUID: 3c10793d-1a2d-490c-9c7d-479f8f2c102b
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS ein realistisches Zieldatum für die Umsetzung der bisher nicht umgesetzten Anforderungen festlegen.

Guidance

Für jede umzusetzende Maßnahme muss ein realistisches Zieldatum festgelegt werden, das den Umfang, die verfügbaren Ressourcen und mögliche Abhängigkeiten berücksichtigt. Die Einhaltung dieser Fristen muss nachgehalten werden. Bei Überschreitung der Fristen sind geeignete Maßnahmen einzuleiten.

Links

related: UMS.3.1 Umsetzungsplanung

Control: UMS.5.1 - Autorisierung von Ausnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: UMS.5 Freigabeverfahren und Ausnahmemanagement

UUID: c3e9f936-827a-4af2-a750-0777a082477d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS Ausnahmegenehmigungen für Verpflichtungen durch eine zuständige Person oder Rolle autorisieren.

Guidance

Bei Zielkonflikten zwischen Verpflichtungen müssen diese gegeneinander abgewogen und falls erforderlich Ausnahmegenehmigungen eingeholt werden. Zur Entscheidungsfindung kann eine Risikobetrachtung vorgenommen werden. Hierbei sind auch die Anforderungen zur "Aufgabenzuweisung" und "Anweisung zur Einhaltung" zu berücksichtigen.

Control: UMS.5.2 - Dokumentation von Ausnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: UMS.5 Freigabeverfahren und Ausnahmemanagement
UUID: df054b8b-955d-42fa-9f35-111b4ac72e98
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS Ausnahmegenehmigungen mit Begründung dokumentieren.

Guidance

Um rechtlich bedeutsame Entscheidungen zur Informationsverarbeitung später nachvollziehen und ggf. anpassen zu können, ist eine Dokumentation dieser Entscheidungen wichtig. Die Dokumentation muss nicht separat von Geschäftsprozessen vorgenommen werden. Vielmehr ist es sogar empfehlenswert, Geschäftsprozesse und Entscheidungsdokumentation zu integrieren, z. B. in CMDBs, Aktenverzeichnissen, Commit-Messages oder Ticketsystemen. Hierbei sind auch die Anforderungen zur "Aufgabenzuweisung" und "Anweisung zur Einhaltung" zu berücksichtigen.

Links

required: UMS.5.1 Autorisierung von Ausnahmen

Control: UMS.6.1 - Nachverfolgung des Umsetzungsfortschritts

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: UMS.6 Fortschrittsverfolgung der Realisierung
UUID: 5ebbee40-3069-4d3e-a708-69f50c017059
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS ein Verfahren für die Nachverfolgung der Umsetzung von Maßnahmen verankern.

Guidance

Es wird empfohlen, dass der Prozess zur Fortschrittsverfolgung der Umsetzung von Anforderungen bzw. Sicherheitsmaßnahmen folgende Aspekte umfasst: Planung und Definition (Zielsetzung, KPI-Definition und detaillierte Umsetzungsplanung), Implementierung (Start der Umsetzung mit klarer Verantwortlichkeit und initialer Bestandsaufnahme), Überwachung (Regelmäßiges Status-Reporting, Soll-Ist-Vergleiche und KPI-Messungen), Bewertung und Anpassung (Ursachenanalyse, Korrekturmaßnahmen und regelmäßige Kommunikation an Stakeholder), Dokumentation und Lessons Learned (Abschlussdokumentation und kontinuierliche Verbesserung mittels PDCA-Zyklus). Eine strukturierte Vorgehensweise gewährleistet, dass Fortschritte transparent nachvollzogen werden, Abweichungen frühzeitig erkannt und der Sicherheitsstatus stetig verbessert werden kann.

Links

required: UMS.3.1 Umsetzungsplanung

Control: UMS.6.2 - Fortschreibung des Umsetzungsplans

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: UMS.6 Fortschrittsverfolgung der Realisierung
UUID: 2383a636-5eab-43e4-b026-c6fbaae7ae56
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS ein Verfahren zur Fortschreibung des Umsetzungsplans veran-
kern.

Guidance

Die Fortschreibung sollte die Anpassung von Zeitplänen und Ressourcenzuweisungen, Neubewertungen von Prioritäten, die Ergänzung neuer Maßnahmen und Streichung nicht mehr relevanter Maßnahmen sowie die Integration von Erkenntnissen aus der Wirksamkeitsprüfung umfassen.

Links

required: UMS.3.1 Umsetzungsplanung

Control: UMS.7.1 - Wahrung von Compliance in der Umsetzung

Tag: "Compliance Management"

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: UMS.7 Wahrung von Compliance in der Umsetzung
UUID: 4409672d-fbc3-4126-b87d-fc33c0f3c253
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Umsetzung MUSS ein Verfahren zur Überprüfung von Compliance im Umsetzungsprozess verankern.

Guidance

Die regelmäßige Überprüfung und Aktualisierung der Compliance-bezogenen Prozesse und Anweisungen stellt sicher, dass sie aktuell und wirksam bleiben, auch wenn sich die regulatorischen Anforderungen ändern. Diese kontinuierliche Anpassung ist ein wesentlicher Bestandteil eines lebendigen und effektiven Compliance-Managements innerhalb des ISMS. Beispiele für ein geeignetes Verfahren kann der Einsatz von Prüflisten oder Auditierung sein.

Links

related: PERF.2.1 Überwachung der Einhaltung von Verpflichtungen

Control: VRB.1.1 - Verfahren zur kontinuierlichen Verbesserung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.1 Kontinuierliche Verbesserung
UUID: af4befb6-3550-4461-bd46-78af23a02817
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Verbesserung MUSS ein Verfahren zur kontinuierlichen Verbesserung des ISMS verankern.

Guidance

In diesem Prozessschritt werden Erkenntnisse aus der Überwachung in konkrete Verbesserungsmaßnahmen umgesetzt. Dieses Verfahren ist ein Prozess, welcher sich im PDCA-Zyklus von der Praktik Strukturmodellierung über die Umsetzung bis hin zum Monitoring und der Evaluierung erstreckt.

Control: VRB.1.2 - Änderungen im ISMS

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: VRB.1 Kontinuierliche Verbesserung

UUID: b7831de9-e3ff-4c82-b6d0-75a90f3f50df

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Verbesserung MUSS ein Verfahren zum Umgang mit Änderungen im ISMS verankern.

Guidance

Änderungen im ISMS erfolgen geplant und strukturiert und werden systematisch dokumentiert. Wenn beispielsweise Parameter in der Risikobetrachtung verändert werden, kann dies Auswirkungen auf die Vergleichbarkeit und Nachvollziehbarkeit sowie die Integrität im Rahmen der Managementbewertung zur Folge haben.

Control: VRB.2.1 - Umgang mit Nicht-Konformitäten

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: VRB.2 Umgang mit Nicht-Konformitäten

UUID: 55056da1-3773-4fb8-b7bf-9d5d7e42f5e6

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Verbesserung MUSS eine Methode zur Überprüfung von Nicht-Konformitäten hinsichtlich Ursachen und Wiederauftreten festlegen.

Guidance

Die Methode sollte eine systematische Erfassung und Dokumentation aller identifizierten Nicht-Konformitäten, unabhängig davon, ob sie durch interne Audits, externe Prüfungen, Vorfälle oder im Rahmen des regulären Betriebs entdeckt wurden, enthalten. Außerdem sollte sie sich auf eine gründliche Ursachenanalyse stützen, die nicht nur die unmittelbaren, sondern auch die grundlegenden Ursachen der Nicht-Konformität identifiziert (Root-Cause-Analysis).

Links

related: VRB.2.2 Anpassung des ISMS

Control: VRB.2.2 - Anpassung des ISMS

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.2 Umgang mit Nicht-Konformitäten
UUID: b2be1d91-1744-467f-abd1-7bcde818fd65
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Verbesserung SOLLTE Notwendigkeit zur Anpassung des ISMS hinsichtlich der Nicht-Konformitäten überprüfen.

Guidance

Hier erfolgt eine Bewertung der Wahrscheinlichkeit des Wiederauftretens von Nicht-Konformitäten und der potenziellen Auswirkungen bei erneutem Auftreten, eine Überprüfung, ob ähnliche Nicht-Konformitäten in anderen Bereichen der Institution bestehen oder auftreten könnten und eine Analyse, inwieweit die Nicht-Konformität auf systemische Schwächen im ISMS hinweist und ob grundlegende Anpassungen des ISMS erforderlich sind. Bei wiederholten oder systematischen Nicht-Konformitäten sollten jedoch die zugrundeliegenden Prozesse, Richtlinien oder Verantwortlichkeiten überprüft und bei Bedarf angepasst werden.

Links

related: VRB.2.1 Umgang mit Nicht-Konformitäten

Control: VRB.3.1 - Identifikation von Verbesserungspotenzialen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.3 Identifikation von Verbesserungspotenzialen
UUID: 9e104747-342c-4fae-a76f-0c3ee159aba5
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Verbesserung SOLLTE eine Methode zur Überprüfung und Bewertung von Verbesserungspotenzialen unter Berücksichtigung der damit verbundenen Risiken verankern.

Guidance

Die Methode beinhaltet beispielsweise die Bewertung des Umfelds der Institution (einschließlich der Bewertung der Gefährdungslage), die Auswertung des Umsetzungsplans, die Auswertung von Auditergebnissen und Sicherheitsvorfällen sowie die Berücksichtigung von Ad hoc-Eingaben (z. B. akute Verbesserungspotentiale).

Control: VRB.4.1 - Korrekturmaßnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.4 Korrektur- und Verbesserungsvorschläge
UUID: 6bfdeefe-8025-4e28-8496-f78fd19f5f7d
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Verbesserung MUSS angemessene Korrekturmaßnahmen zur Beseitigung der Ursachen von Fehlern festlegen.

Guidance

Im Gegensatz zum reaktiven Umgang mit Nicht-Konformitäten zielt dieser Ansatz darauf ab, auch ohne vorangegangene Probleme oder Abweichungen Optimierungsmöglichkeiten zu erkennen und zu nutzen. Bei der Bewertung von Verbesserungspotenzialen ist eine risikoorientierte Herangehensweise wichtig. Nicht jede Verbesserungsmöglichkeit bietet denselben Mehrwert für die Institution. Die Bewertung sollte das Potenzial zur Risikoreduktion, den erwarteten Ressourcenaufwand, die strategische Bedeutung für die Informationssicherheitsziele, mögliche Synergien mit anderen Verbesserungsmaßnahmen oder Projekten und die Nachhaltigkeit der Verbesserung berücksichtigen.

Control: VRB.4.2 - Verbesserungsmaßnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.4 Korrektur- und Verbesserungsvorschläge
UUID: 72bd4983-953e-42ec-9870-113fb0d8c079
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Verbesserung MUSS angemessene Maßnahmen zur Nutzung von Verbesserungspotentialen unter Berücksichtigung der damit verbundenen Risiken festlegen.

Guidance

Für Verbesserungen zur Nutzung identifizierter Potenziale sollte ein strukturierter Ansatz verfolgt werden. Diese zielen auf die proaktive Weiterentwicklung des ISMS ab. Sie können beispielsweise den Einsatz neuer oder verbesserter Technologien und Methoden, die Stärkung der Sicherheitskultur und des Sicherheitsbewusstseins, die Erweiterung des Anwendungsbereiches des ISMS oder die Verbesserung der Integration des ISMS in andere Managementsysteme und Geschäftsprozesse betreffen.

Links

required: VRB.3.1 Identifikation von Verbesserungspotenzialen

Control: VRB.5.1 - Priorisierung von Maßnahmen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.5 Korrektur- und Verbesserungsplan
UUID: fe0b2f60-809f-4ea6-a956-26aa3c6afde6
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Verbesserung MUSS den Maßnahmen zur Korrektur und Verbesserung Prioritäten zuweisen.

Guidance

Maßnahmen zur Verbesserung müssen in den Umsetzungsplan einfließen. Dort werden die Zuständigen für die Umsetzung, Zieldatum der Umsetzung, die Anforderungsbeschreibung, das Zielobjekt bzw. den Anwendungsbereich, die verantwortliche Stelle, Start- und Zieldatum (Fristen), Prioritäten, Status der Umsetzung, ergänzende Aktivitäten z. B. Schulungen, Risiken inkl. Begründung (Was bleibt offen? Was wurde nicht umgesetzt und warum?), Ressourcenplanung, Abhängigkeiten zu anderen Anforderungen, sowie Datum der Freigabe und Unterschrift des Risikoeigentümers nachverfolgt.

Links

required: VRB.4.2 Verbesserungsmaßnahmen

required: VRB.4.1 Korrekturmaßnahmen

Control: VRB.6.1 - Wirksamkeitsprüfung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"

Gruppe: VRB.6 Wirksamkeitsprüfung

UUID: 89d9eada-bcdb-4b47-a3de-b26e22cca2a4

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Verbesserung MUSS die Wirksamkeit der umgesetzten Maßnahmen {{ insert: param, vrb.6.1-prm1 }} überprüfen.

Guidance

Die Wirksamkeit bewertet, ob die Maßnahmen den beabsichtigten Effekt erzielt haben. Hierfür sollten die Definition klarer, messbarer Kriterien für die Wirksamkeit jeder Maßnahme, die Durchführung gezielter Tests, Audits oder Überprüfungen nach Abschluss der Umsetzung, die Bewertung, ob die identifizierten Nicht-Konformitäten tatsächlich beseitigt oder die angestrebten Verbesserungen erreicht wurden sowie die Dokumentation der Ergebnisse der Wirksamkeitsprüfung berücksichtigt werden.

Control: VRB.7.1 - Bewertung der erreichten Verbesserung

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.7 Bewertung der erreichten Verbesserung
UUID: 148975f6-1a20-4fe6-9d3b-b6e69ec80ec5
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Verbesserung SOLLTE ein Verfahren zur Bewertung der erreichten Verbesserung unter Berücksichtigung der damit verbundenen Risiken verankern.

Guidance

Die Bewertung kann beispielsweise durch interne Audits, die Messung von Key Performance Indicators (KPIs) vor und nach der Maßnahmenumsetzung oder durch technische Überprüfungen erfolgen. Im Ergebnis ist das Sicherheitsniveau der Institution transparent dargestellt und Trends der Verbesserung des Sicherheitsniveaus, insbesondere auch durch die Vergleichbarkeit mit vorigen Bewertungen, ableitbar.

Control: VRB.8.1 - Behandlung von Compliance-Verstößen

Info

Control der Klasse "BSI-Methodik-Grundschutz-plus-plus"
Gruppe: VRB.8 Behandlung von Compliance-Verstößen
UUID: 8a5be79d-22b6-4a78-a87e-6445c9fdd20d
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Verbesserung SOLLTE ein Verfahren zur Behandlung von Verstößen unter Berücksichtigung der Betroffenenrechte verankern.

Guidance

Das Verfahren sollte eine klare Definition enthalten, was als Verstoß gilt und die verschiedenen Arten von Verstößen kategorisieren. Es sollten Melde- und Eskalationswegen für erkannte oder vermutete Verstöße festgelegt werden, ein systematischer Prozess zur Untersuchung und Dokumentation von Verstößen etabliert werden, eine Entscheidungsfindung über angemessene Reaktionen und Konsequenzen stattfinden und die Umsetzung beschlossener Maßnahmen sollte nachverfolgt werden.

Links

related: GC.7.1.1 Gesetzliche Verpflichtungen

related: UMS.7.1 Wahrung von Compliance in der Umsetzung